

(Ticket-Granting Server)。Kerberos 只用于客户与服务器之间的鉴别，而不适用于人对人的鉴别。在图 7-14 中，A 是请求服务的客户，而 B 是被请求的服务器。A 通过 Kerberos 向 B 请求服务。Kerberos 需要通过以下六个步骤鉴别的确是 A（而不是其他人冒充 A）向 B 请求服务后，才向 A 和 B 分配会话使用的密钥。下面简单解释各步骤。

❶ A 用明文（包括登记的身份）向鉴别服务器 AS 表明自己的身份。AS 就是 KDC，它掌握各实体登记的身份和相应的口令。AS 对 A 的身份进行验证。只有验证结果正确，才允许 A 和票据授予服务器 TGS 进行联系。

❷ 鉴别服务器 AS 向 A 发送用 A 的对称密钥 K_A 加密的报文，这个报文包含 A 和 TGS 通信的会话密钥 K_S 以及 AS 要发送给 TGS 的票据（这个票据是用 TGS 的对称密钥 K_{TG} 加密的）。A 并不保存密钥 K_A ，但当这个报文到达 A 时，A 就键入其口令。若口令正确，则该口令和适当的算法一起就能生成密钥 K_A 。这个口令随即被销毁。密钥 K_A 用来对 AS 发送过来的报文进行解密。这样就提取出会话密钥 K_S （这是 A 和 TGS 通信要使用的）以及要转发给 TGS 的票据（这是用密钥 K_{TG} 加密的）。

❸ A 向 TGS 发送三项内容：

- 转发鉴别服务器 AS 发来的票据。
- 服务器 B 的名字。这表明 A 请求 B 的服务。请注意，现在 A 向 TGS 证明自己的身份并非通过键入口令（因为入侵者能够从网上截获明文口令），而是通过转发 AS 发出的票据（只有 A 才能提取出）。票据是加密的，入侵者伪造不了。
- 用 K_S 加密的时间戳 T 。它用来防止入侵者的重放攻击。

❹ TGS 发送两个票据，每一个都包含 A 和 B 通信的会话密钥 K_{AB} 。给 A 的票据用 K_S 加密；给 B 的票据用 B 的密钥 K_B 加密。请注意，现在入侵者不能提取 K_{AB} ，因为不知道 K_S 和 K_B 。入侵者也不能重放步骤❸，因为入侵者不能把时间戳更换为一个新的（因为不知道 K_S ）。如果入侵者在时间戳到期之前，非常迅速地发送步骤❸的报文，那么对 TGS 发送过来的两个票据仍然不能解密。

❺ A 向 B 转发 TGS 发来的票据，同时发送用 K_{AB} 加密的时间戳 T 。

❻ B 把时间戳 T 加 1 来证实收到了票据。B 向 A 发送的报文用密钥 K_{AB} 加密。

以后，A 和 B 就使用 TGS 给出的会话密钥 K_{AB} 进行通信。

顺便指出，Kerberos 要求所有使用 Kerberos 的主机必须在时钟上进行“松散的”同步。所谓“松散的”同步是要求所有主机的时钟误差不能太大，例如，不能超过 5 分钟的数量级。这个要求是为了防止重放攻击。TGS 发出的票据都设置较短的有效期。超过有效期的票据就作废了。因此入侵者即使截获了某个票据，也不能长期保留用来进行以后的重放攻击。

7.4.2 公钥的分配

在公钥密码体制中，公钥的分配方法并不简单。本节就讨论这个问题。

我们不妨先假定大家都各自保存有自己的私钥，而把各自的公钥发布在网上。假定 A 和 B 都是公司。有个捣乱者给 A 发送邮件，声称自己是 B，要购买 A 生产的设备，货到付款，并给出了 B 的收货地址。邮件中还附上“B 的公钥”（其实是捣乱者的公钥）。最后用捣乱者的私钥对邮件进行了签名。A 收到邮件后，就用邮件中给出的捣乱者的公钥（A 以为自己使用了 B 的公钥），对邮件中的签名进行了鉴别，就误认为 B 真的是要购买设备。当 A

把生产的设备运到 B 的地址后, B 才知道被愚弄了! 捣乱者甚至还可伪造一个冒充 B 的网站, 上面有“B 的公钥”(其实是捣乱者的公钥)。

那么, 有没有可靠的方法来获得 B 的公钥, 并且能确信公钥是真的?

有一种非常可靠的方法, 就是公司 A 派人亲自去公司 B, 直接向公司 B 索要其公钥。这样拿到的 B 的公钥当然是可信任的。但这种很不方便的办法显然不能普遍推广使用。

现在流行的办法, 这就是找一个可信任的第三方机构(第三方机构既不是需要 B 的公钥的公司 A, 也不是拥有公钥的公司 B), 给拥有公钥的实体发一个具有数字签名的数字证书(digital certificate), 有时也可简称为证书。数字证书就是对公钥与其对应的实体(人或机器)进行绑定(binding)一个证明。因此它常称为公钥证书。这种签发证书的机构就叫作认证中心 CA (Certification Authority), 它由政府或知名公司出资建立(这样就可以得到大家的信任)。每个证书中写有公钥及其拥有者的标识信息(人名、地址、电子邮件地址或 IP 地址等)。更重要的是, 证书中有 CA 使用自己私钥的数字签名, 这就是认证中心 CA 把 B 的未签名的证书进行散列函数运算, 再用 CA 的私钥对散列值进行 D 运算(也就是对散列值进行签名)。这样就得到了 CA 的数字签名。把 CA 的数字签名和未签名的 B 的证书放在一起, 就最后构成了已签名的 B 的数字证书(如图 7-15 所示)。图中的数字证书只给出了最重要的几个项目。这样的证书无法伪造。任何用户都可从可信任的地方(如代表政府的报纸)获得认证中心 CA 的公钥, 以验证证书的真伪。这种数字证书是公开的, 不需要加密。现在我国的认证中心已有不少, 例如, 在金融领域, 中国金融认证中心 CFCA (China Financial Certification Authority)是由中国人民银行牵头, 联合 14 家全国性商业银行共同建立的金融认证机构, 其权威性是毋庸置疑的。在国际上, 威瑞信公司 VeriSign 是发行数字证书产品的一家具有权威性的公司。



图 7-15 已签名的 B 的数字证书的产生过程

公司 A 拿到 B 的数字证书后, 可以对 B 的数字证书的真实性进行核实。A 使用数字证书上给出的 CA 的公钥, 对数字证书中 CA 的数字签名进行 E 运算, 得出一个数值。再对 B 的数字证书(把 CA 的数字签名除外的部分)进行散列运算, 又得出一个数值。比较这两个数值。若一致, 则数字证书是真的。当 A 收到包含有 B 的数字签名的订货单时, 也能用类似的方法, 对订单的真实性进行核实(使用 B 的数字证书中给出的 B 的公钥)。

为了使 CA 发布的数字证书在各行各业中能够通用, 数字证书的格式就必须标准化。为此, ITU-T 制定了 X.509 协议标准, 后来 IETF 采用了现在的版本, 即 X.509 V3 [RFC 5280], 作为互联网的推荐标准(147 页)。X.509 又称为互联网公钥基础结构 PKI (Public Key Infrastructure)。

X.509 规定了一个数字证书必须包括以下这些重要字段:

- X.509 的版本
- 数字证书名称及序列号

- 本数字证书所使用的签名算法
- 数字证书签发者的唯一标识符
- 数字证书的有效期（有效期开始到结束的日期范围）
- 主体名（或主题名，公钥和数字证书拥有者的唯一标识符）
- 公钥（数字证书拥有者的公钥和使用算法的标识符，对应的私钥由证书拥有者保存）

X.509 提出把多级认证中心链接起来的，构成一个树状的认证系统（如图 7-16(a)所示）。在多级认证系统的末端就是用户（A~E）。在 X.509 中并没有规定这种链接需要多少级，也没有给每一级的认证中心规定统一的名称。但最高一级的认证中心都称为**根认证中心**（Root CA），即公认可信的认证中心（或无条件信任的），且其公钥是公开的。在这种树状的认证系统中，可以有不止一个根 CA。从根 CA 向下的所有链接都称为**信任链**，表示处在这条链接上的认证机构都是可信的。

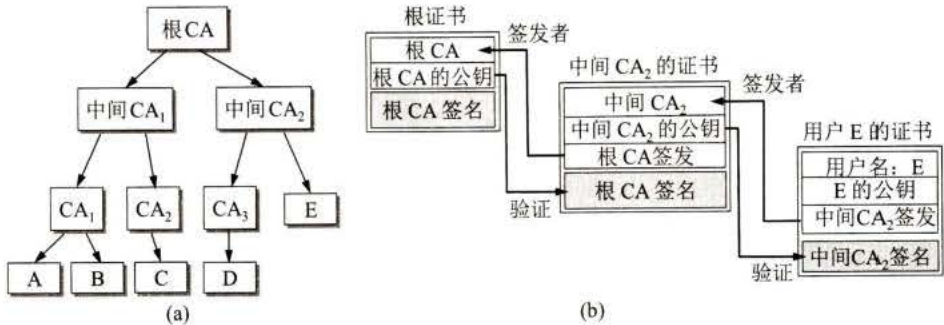


图 7-16 树状结构的多级认证系统(a)和证书链(b)

图 7-16(a)最右边的一串链接就是一条信任链的例子：根 CA→中间 CA₂→用户 E。与这条信任链对应的是**证书链**（如图 7-16(b)所示），通过图中所示的链接，就可以查到本证书的签发者，也可以知道用谁的公钥来验证本证书中的签名。在这条证书链中，根 CA 给中间 CA₂ 签发了中间证书，并使用根 CA 的私钥进行数字签名。中间 CA₂ 可以用根 CA 的公钥，对证书中的根 CA 签名进行验证。因此中间证书是可信的和不可篡改的。同理，中间 CA₂ 给下面的一个用户签发了用户证书，并使用中间 CA₂ 的私钥进行数字签名。用户可以用中间 CA₂ 的公钥，对用户证书中的中间 CA₂ 的签名进行验证。因此，这个用户证书也是可信的和不可篡改的。请注意，最顶层的根证书的数字签名是**自签名**（即自己的私钥给自己签名）。根证书不需要其他的认证机构对其签名，是我们的信任链的起点。

若证书链中的某个认证中心没有严格遵守证书所规定的要求（例如，把证书转让给了其他单位，但并未严格验证其身份），那么这个节点以下的证书是否还可信，就应重新验证。用户若发现私钥被盗或遗失，应及时报告上级 CA，以便撤销证书。每一个 CA 应当有一个公布于众的、用本 CA 的私钥签名**证书撤销名单**，并定期更新。

7.5 互联网使用的安全协议

前面几节所讨论的网络安全原理都可用在互联网中，目前在网络层、运输层和应用层都有相应的网络安全协议。下面分别介绍这些协议的要点。

7.5.1 网络层安全协议

1. IPsec 协议族概述

我们在第 4 章的 4.8.1 节中讨论虚拟专用网 VPN 时，提到在 VPN 中传送的信息都是经过加密的。现在我们要介绍提供这种加密服务的 IPsec。

IPsec 并不是单一的协议，而是能够在 IP 层提供互联网通信安全的协议族（不太严格的名词“IPsec 协议”也常见到）。实际上，IPsec 包含了一个通用框架和若干加密算法，具有相当的灵活性和可扩展性。IPsec 允许通信双方从中选择合适的算法和参数（例如，密钥长度），以及是否使用鉴别。为保证互操作性，IPsec 规定其所有的实现都必须包含 IPsec 所推荐的全部加密算法。

IPsec 就是“IP 安全(security)”的缩写。在很多 RFC 文档中已给出了详细的描述。在这些文档中，最重要的就是描述 IP 安全体系结构的 RFC 4301（目前是建议标准）和提供 IPsec 协议族概述的 RFC 6071。

IPsec 协议族中的协议可划分为以下三个部分：

- (1) IP 安全数据报格式的两个协议：鉴别首部 AH (Authentication Header)协议和封装安全有效载荷 ESP (Encapsulation Security Payload)协议。
- (2) 有关加密算法的三个协议。
- (3) 互联网密钥交换 IKE (Internet Key Exchange)协议。

下面我们要重点介绍 IP 安全数据报的格式，以便了解 IPsec 怎样提供网络层的安全通信。AH 协议提供源点鉴别和数据完整性，但不能保密。而 ESP 协议比 AH 协议复杂得多，它提供源点鉴别、数据完整性和保密。IPsec 支持 IPv4 和 IPv6。在 IPv6 中，AH 和 ESP 都是扩展首部的一部分。AH 协议的功能都已包含在 ESP 协议中，因此使用 ESP 协议就可以不使用 AH 协议。下面我们将不再讨论 AH 协议，而只介绍 ESP 协议的要点。

使用 ESP 或 AH 协议的 IP 数据报称为 IP 安全数据报（或 IPsec 数据报），它可以在两台主机之间、两个路由器之间或一台主机和一个路由器之间发送。

IP 安全数据报有以下两种不同的工作方式。

第一种工作方式是**运输方式(transport mode)**。运输方式是在整个运输层报文段的前后分别添加若干控制信息，再加上 IP 首部，构成 IP 安全数据报（见图 7-17(a)）。

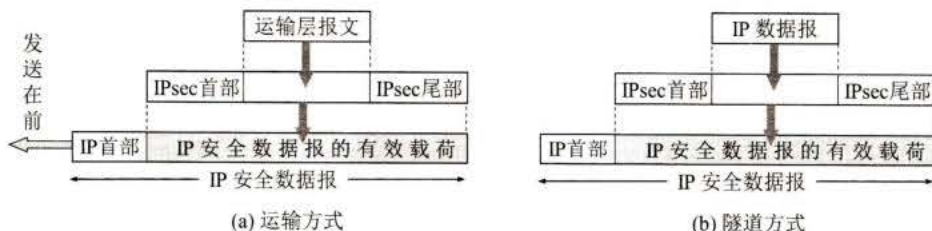


图 7-17 IP 安全数据报的两种工作方式

第二种工作方式是**隧道方式(tunnel mode)**。隧道方式是在原始的 IP 数据报的前后分别添加若干控制信息，再加上新的 IP 首部，构成一个 IP 安全数据报（见图 7-17(b)）。

无论使用哪种方式，最后得出的 IP 安全数据报的 IP 首部都是不加密的。只有使用不加密的 IP 首部，互联网中的各个路由器才能识别 IP 首部中的有关信息，把 IP 安全数据报在不安全

的互联网中进行转发，从源点安全地转发到终点。所谓“安全数据报”是指数据报的数据部分是经过加密的，并能够被鉴别的。通常把数据报的数据部分称为数据报的有效载荷(payload)。

由于目前使用最多的就是隧道方式，因此下面的讨论只限于隧道方式。

2. 安全关联

在发送 IP 安全数据报之前，在源实体和目的实体之间必须创建一条网络层的逻辑连接，即安全关联 SA (Security Association)。这样，传统的互联网中无连接的网络层就变为了具有逻辑连接的一个层。安全关联是从源点到终点的单向连接，它能够提供安全服务。如要进行双向安全通信，则两个方向都需要建立安全关联。假定某公司有一个公司总部和一个在外地的分公司。总部需要和这个分公司以及在各各地出差的 n 个员工进行双向安全通信。在这种情况下，一共需要创建 $(2 + 2n)$ 条安全关联 SA。在这些安全关联 SA 上传送的就是 IP 安全数据报。

图 7-18(a)是安全关联 SA 的示意图。公司总部和分公司都各有一个负责收发 IP 数据报的路由器 R_1 和 R_2 （通常就是公司总部和分公司的防火墙中的路由器），而公司总部与分公司之间的安全关联 SA 就是在路由器 R_1 和 R_2 之间建立的。当然，路由器 R_1 和 R_2 都必须预先装有 IPsec。现假定公司总部的主机 H_1 要和分公司的主机 H_2 通过互联网进行安全通信。

公司总部主机 H_1 发送给分公司主机 H_2 的 IP 数据报，必须先经过公司总部的路由器 R_1 。然后经 IPsec 的加密处理后，成为 IP 安全数据报。这样就把原始的 IP 数据报隐藏在 IP 安全数据报中了。IP 安全数据报经过互联网中很多路由器的转发，最后到达分公司的路由器 R_2 。路由器 R_2 对 IP 安全数据报解密，还原出原始的数据报，传送到终点主机 H_2 。从逻辑上看，IP 安全数据报在安全关联 SA 上传送，就好像通过一个安全的隧道。这就是“隧道方式”这一名词的来源。如果总部的主机 H_1 要和总部的另一台主机 H_3 通信，由于都在公司内部，不需要加密，因此不需要建立安全关联。 H_1 发出的 IP 数据报只需通过总部内部的路由器 R_1 转发一次即可送到 H_3 。如果 H_1 要上网查看天气预报，同样不需要建立安全关联，而是发送 IP 数据报，经过路由器 R_1 转发到互联网中的下一个路由器，最后到达互联网中预报气象的服务器。

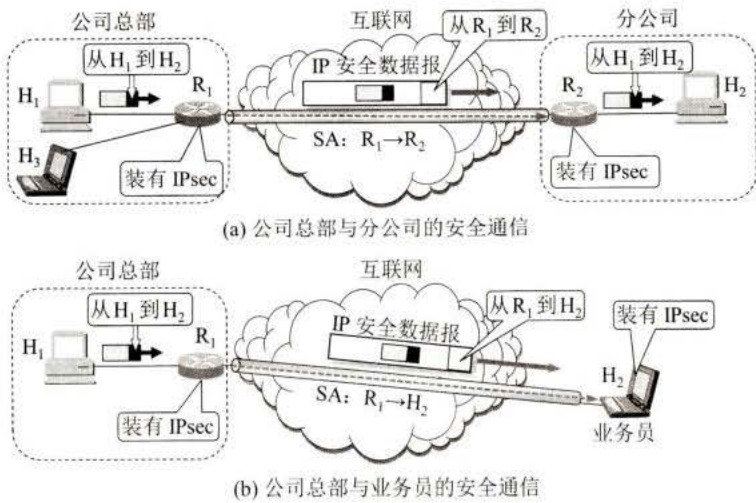


图 7-18 安全关联 SA 的示意图

若公司总部的主机 H_1 要和某外地业务员的便携机 H_2 进行安全通信, 则情况将稍有不同 (如图 7-18(b)所示)。可以看出, 这时公司总部的路由器 R_1 和外地业务员的便携机 H_2 建立安全关联 SA (即路由器和主机之间的安全关联)。公司总部 H_1 发送的 IP 数据报, 通过路由器 R_1 后, 就变成了 IP 安全数据报。经过互联网中许多路由器的转发, 最后到达 H_2 。可以看出, 现在是在路由器 R_1 和业务员的便携机 H_2 之间构成了一个安全隧道。外地业务员利用事先安装在便携机 H_2 中的 IPsec 对 IP 安全数据报进行鉴别和解密, 还原 H_1 发来的 IP 数据报。

建立安全关联 SA 的路由器或主机, 必须维护这条 SA 的状态信息。我们以图 7-18 中的安全关联 SA 为例, 说明其状态信息应包括的项目:

- (1) 一个 32 位的连接标识符, 称为安全参数索引 SPI (Security Parameter Index)。
- (2) 安全关联 SA 的源点和终点的 IP 地址 (即路由器 R_1 和 R_2 的 IP 地址)。
- (3) 所使用的加密类型 (例如, DES 或 AES)。
- (4) 加密的密钥。
- (5) 完整性检查的类型 (例如, 使用报文摘要 MD5 或 SHA-1 的报文鉴别码 MAC)。
- (6) 鉴别使用的密钥。

当路由器 R_1 要通过 SA 发送 IP 安全数据报时, 就必须读取 SA 的这些状态信息, 以便知道如何把 IP 数据报进行加密和鉴别。

3. IP 安全数据报的格式

图 7-19 是 IP 安全数据报的格式。下面以隧道方式为例, 结合各字段的作用, 讨论一下 IP 安全数据报是怎样构成的。图中的数字①至⑥表示 IP 安全数据报构成的先后顺序。

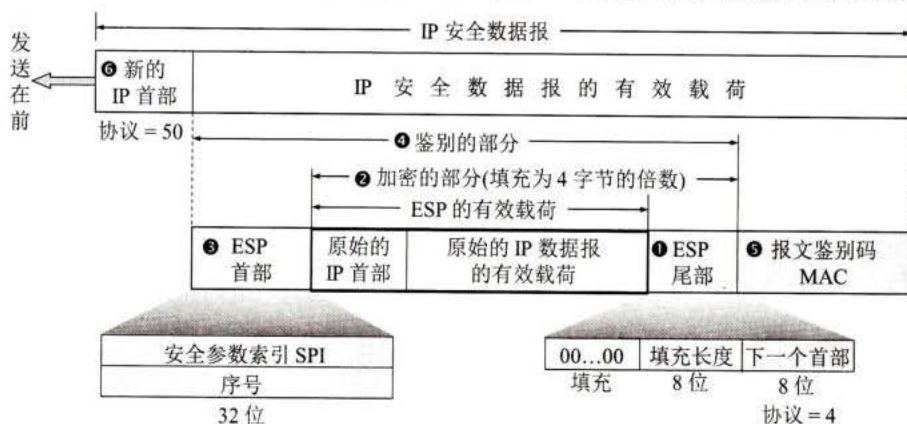


图 7-19 IP 安全数据报的格式

① 首先在原始的 IP 数据报 (也就是 ESP 的有效载荷) 后面添加 ESP 尾部。ESP 尾部有三个字段。第一个字段是填充字段, 用全 0 填充。第二个字段是填充长度 (8 位), 指出填充字段的字节数。为什么要进行填充呢? 这是因为在进行数据加密时, 通常都要求数据块长度是若干字节 (例如, 4 字节) 的整数倍。当 IP 数据报长度不满足此条件时, 就必须用 0 进行填充。每个 0 为一个字节长。虽然填充长度 (8 位) 的最大值是 255, 但实际上, 填充很少会用到这个最大值。ESP 尾部最后一个字段是 “下一个首部” (8 位)。这个字段的值指明, 在接收端, ESP 的有效载荷应交给哪个协议来处理。如图 7-19 所示, IP 安全数据报有

三个首部。现在 ESP 尾部中的“下一个首部”显然就是指 ESP 的有效载荷中的“原始的 IP 首部”，IP 的协议值是 4，因此“下一个首部”应填入的数值是 4。如果不是隧道方式而是运输方式，则“ESP 的有效载荷”就应当是 TCP 或 UDP 报文段，“下一个首部”的值也要改为另外的数值。

② 按照安全关联 SA 指明的加密算法和密钥，对“ESP 的有效载荷（即原始的 IP 数据报）+ ESP 尾部”（见图 7-19 中的“加密的部分”）进行加密。

③ 对“加密的部分”完成加密后，就添加 ESP 首部。ESP 首部有两个 32 位字段。第一个字段存放安全参数索引 SPI。通过同一个 SA 的所有 IP 安全数据报都使用同样的 SPI 值。第二个字段是序号，鉴别要用到这个序号，它用来防止重放攻击。请注意，当分组重传时序号并不重复。

④ 按照 SA 指明的算法和密钥，对“ESP 首部 + 加密的部分”（见图 7-19 中的“鉴别的部分”）生成报文鉴别码 MAC。

⑤ 把所生成的报文鉴别码 MAC 添加在 ESP 尾部的后面，和 ESP 首部、ESP 的有效载荷、ESP 尾部一起，构成 IP 安全数据报的有效载荷。

⑥ 生成新的 IP 首部，通常为 20 字节长，和普通的 IP 数据报的首部的格式是一样的。需要注意的是，首部中的协议字段的值是 50，表明在接收端，首部后面的有效载荷应交给 ESP 协议来处理。

当分公司的路由器 R₂ 收到 IP 安全数据报后，先检查首部中的目的地址。发现目的地址就是 R₂，于是路由器 R₂ 就继续处理这个 IP 安全数据报。

路由器 R₂ 找到 IP 首部的协议字段值（现在是 50），就把 IP 首部后面的所有字段（即 IP 安全数据报的有效载荷）都用 ESP 协议进行处理。先检查 ESP 首部中的安全参数索引 SPI，以确定收到的数据报属于哪一个安全关联 SA（因为路由器 R₂ 可能有多个安全关联）。路由器 R₂ 接着计算报文鉴别码 MAC，看是否和 ESP 尾部后面添加的报文鉴别码 MAC 相符。如是，即知收到的数据报的确是来自路由器 R₁。再检验 ESP 首部中的序号，以证实有无被入侵者重放。接着要用和这个安全关联 SA 对应的加密算法和密钥，对已加密的部分进行解密。再根据 ESP 尾部中的填充长度，去除发送端填充的所有 0，还原出加密前的 ESP 有效载荷，也就是 H₁ 发送的原始 IP 数据报。

根据解密后得到的 ESP 尾部中“下一个首部”的值（现在是 4），把 ESP 的有效载荷交给 IP 来处理。当找到原始的 IP 首部中的目的地址是主机 H₂ 的 IP 地址时，就把整个的 IP 数据报传送给主机 H₂。整个 IP 数据报的传送过程到此结束。

请注意，在图 7-19 的“原始的 IP 首部”中，是用主机 H₁ 和 H₂ 的 IP 地址分别作为源地址和目的地址，而在 IP 安全数据报的“新的 IP 首部”中，是使用路由器 R₁ 和 R₂ 的 IP 地址分别作为源地址和目的地址（这是图 7-18(a)所示的情况）。但如果是图 7-18(b)所示的情况，IP 安全数据报不经过另一个路由器 R₂，那么在 IP 安全数据报的“新的 IP 首部”中，要用路由器 R₁ 和主机 H₂ 的 IP 地址分别作为 IP 安全数据报的源地址和目的地址。

从以上的讨论可以看出，设想有一个 IP 安全数据报在互联网中被某人截获，如果截获者不知道此安全数据报的密码，那么他只能知道这是一个从路由器 R₁ 发往路由器 R₂ 的 IP 数据报，但却无法看懂其有效载荷中的数据含义。如果截获者篡改了数据报的源地址，那么安全数据报的鉴别功能可以保证源地址的真实性。假定截获者故意删除了安全数据报中的一些字节，但由于接收端的路由器 R₂ 能够进行完整性检验，就不会接收这种含有差错的信息。

如果截获者试图进行重放攻击，那么由于安全数据报使用了有效的序号，使得重放攻击也无法得逞。

4. IPsec 的其他构件

前面已经提到过，发送 IP 安全数据报的实体可能要用到很多条安全关联 SA。那么这些 SA 存放在什么地方呢？这就要提及 IPsec 的一个重要构件，叫作**安全关联数据库 SAD** (Security Association Database)。所有需要运行 IPsec 的站点都必须有 SAD。当主机要发送 IP 安全数据报时，就要在 SAD 中查找相应的 SA，以便获得必要的信息，来对该 IP 安全数据报实施安全保护。同样，当主机要接收 IP 安全数据报时，也要在 SAD 中查找相应的 SA，以便获得信息来检查该分组的安全性。

前面已经提到了，主机所发送的数据报并非都必须进行加密，很多信息使用普通的数据报用明文发送即可。因此，除了安全关联数据库 SAD，还需要另一个数据库，这就是**安全策略数据库 SPD** (Security Policy Database)。SPD 指明什么样的数据报需要进行 IPsec 处理。这取决于源地址、源端口、目的地址、目的端口，以及协议的类型等。因此，当一个 IP 数据报到达时，SPD 指出应当做什么（使用 IP 安全数据报还是不使用），而 SAD 则指出，如果需要使用 IP 安全数据报，应当怎样做（使用哪一个 SA）。

还有一个问题，安全关联数据库 SAD 中存放的许多安全关联 SA 是怎样建立起来的呢？如果一个虚拟专用网 VPN 只有几个路由器和主机，那么用人工键入的方法就可以建立起所需的安全关联数据库 SAD。但如果一个 VPN 有好几百或几千个路由器和主机，人工键入的方法显然是不行的。因此，对于大型的、地理位置分散的系统，为了创建 SAD，我们需要使用自动生成的机制，即使用**互联网密钥交换 IKE** (Internet Key Exchange) 协议。IKE 的用途就是为 IP 安全数据报创建安全关联 SA。

IKE 是个非常复杂的协议，IKEv2 是其新的版本，在 2014 年 10 月已成为互联网的正式标准[RFC 7296, STD79]。IKEv2 以另外三个协议为基础：

- (1) Oakley——是个密钥生成协议[RFC 2412]。
- (2) 安全密钥交换机制 SKEME (Secure Key Exchange MEchanism) ——是用于密钥交换的协议。它利用公钥加密来实现密钥交换协议中的实体鉴别。
- (3) 互联网安全关联和密钥管理协议 ISAKMP (Internet Secure Association and Key Management Protocol) ——用于实现 IKE 中定义的密钥交换，使 IKE 的交换能够以标准化、格式化的报文创建安全关联 SA。

关于 IKE 的深入介绍可参阅有关文档，如 RFC 4945 和 RFC 7427（都是建议标准）。

7.5.2 运输层安全协议

1. 协议 TLS 的要点

当万维网能够提供网上购物时，安全问题就马上被提到桌面上来了。例如，当顾客在不安全的互联网上购物时，他会要求得到下列安全服务：

- (1) 顾客需要确保服务器属于真正的销售商，而不是某个冒充者。这就是应对身份进行鉴别。
- (2) 顾客与销售商需要确保报文的内容（例如账单）在传输过程中没有被篡改。这就是

应保证通信内容的**数据完整性**。

(3) 顾客与销售商需要确保诸如信用卡上的敏感信息不被泄露。这就是要有**机密性**。

不仅在电子商务领域，即使在我们日常上网浏览各种信息时，我们所浏览的信息也是属于个人隐私，不应作为网上的公开信息。因此，在很多情况下，客户端（浏览器）与服务 器之间的通信需要使用安全的运输层协议。曾经广泛使用的运输层安全协议有两个，即：(1) **安全套接字层 SSL (Secure Socket Layer)**。(2) **运输层安全 TLS (Transport Layer Security)**。

协议 SSL 是 Netscape 公司在 1994 年开发的安全协议，广泛应用于基于万维网的各种网 络应用（但不限于万维网应用）。SSL 作用在端系统应用层的 HTTP 和运输层之间，在 TCP 之上建立起一个安全通道，为通过 TCP 传输的应用层数据提供安全保障。

1995 年 Netscape 公司把协议 SSL 转交给 IETF，希望能够把 SSL 进行标准化。1999 年 IETF 在 SSL 3.0 的基础上设计了协议 TLS 1.0（改动极少），为所有基于 TCP 的网络应用提供 安全数据传输服务。为了应对网络安全的变化，IETF 及时地对 TLS 的版本进行升级，如 2006 年的 TLS 1.1，2008 年的 TLS 1.2。2014 年 10 月，谷歌建议禁用 SSL 3.0，因为其设计上 有漏洞，用户的敏感信息有被窃取的可能。接着，Mozilla 和微软也发出了同样的安全通告。 2018 年 8 月 IETF 发布了经历了 28 个草案后才通过的最新版本 TLS 1.3 [RFC 8446，建议标准] （不向后兼容）。在 2020 年，旧版本 TLS 1.0/1.1 均被废弃。目前谷歌浏览器 Chrome 和火狐 浏览器 Firefox 都已开始使用更加安全的协议 TLS 1.3，但不少老客户端仍未抛弃一些旧版本。 应当说，到目前为止协议 TLS 1.2 还是安全可用的，只是被发现了有潜在的安全隐患。因此， 现在能够使用的运输层安全协议就只剩下协议 TLS 1.2 和协议 TLS 1.3 了。

协议 TLS 的位置在运输层和应用层之间（如图 7-20 所示）。虽然协议 SSL 2.0/3.0 均已 被废弃不用了，但现在还经常能够看到把“SSL/TLS”视为 TLS 的同义词。这是因为协议 TLS 本来就源于 SSL（但并不兼容），而现在旧协议 SSL 被更新为新协议 TLS。

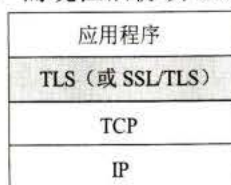


图 7-20 协议 TLS 位于运输层和应用层之间

应用层使用协议 TLS 最多的就是 HTTP，但并非仅限于 HTTP。因为协议 TLS 是对 TCP 加密，因此任何在 TCP 之上运行的应用程序都可以使用协议 TLS。例如，用于 IMAP 邮件存取的鉴别和数据加密也可以使用 TLS。TLS 提供了一个简单的带有套接字的应用程 序接口 API，这和 TCP 的 API 是相似的。

当不需要运输层安全协议时，HTTP 就直接使用 TCP 连接，这时协议 TLS 不起作用。 由于需要使用运输层安全协议的人越来越多，因此现在相当多的网站已是全站使用运输层安 全协议。例如，当我们使用百度网站浏览信息时，在浏览器的地址栏键入其官网地址 www.baidu.com 后（不必在前面键入 http://或 https://），就可以在屏幕上看到这样的响应：

 https://www.baidu.com

可以看出，尽管用户在浏览器上没有键入 https://，但百度网站总是提供安全的运输层 服务。提供安全运输层服务的标志是地址栏 URL 中的协议部分显示出的是 https，并且在其

左边还有一个安全锁  的标志。在 http 后面加上的 s 代表 security，表明是使用 HTTPS，即提供安全服务的 HTTP 协议（TCP 的 HTTPS 端口号是 443，而不是 HTTP 使用的端口号 80）。这时我们就可以放心和这样的网站进行通信，因为这个网站已经被鉴别了是真正的百度网站，并且之后在浏览器和百度服务器之间的所有交互报文都是加密的，因而通信的机密性得到了保证。

现在我们使用某些主流浏览器访问不安全的网站时，浏览器会向用户发出“不安全”的警告。下面给出当我们键入桔梗网的网址 shu.jiegeng.com 后所看到的响应：

谷歌 Chrome 浏览器指出“不安全”

① 不安全 | shu.jiegeng.com

火狐 Firefox 浏览器提示无安全锁

🔒 shu.jiegeng.com

这就提醒我们在上网时要注意信息的安全。

协议 TLS 具有双向鉴别的功能。但大多数情况下使用的是单向鉴别，即客户端（浏览器）需要鉴别服务器。也就是说，浏览器 A 要确信即将访问的网站服务器 B 是安全和可信的。这必须要有两个前提。首先，服务器 B 必须能够证明本身是安全和可信的。因此服务器 B 需要有一个证书来证明自己。现在我们假定服务器 B 已经持有了有效的 CA 证书。这正是运输层安全协议 TLS 的基石。其次，浏览器 A 应具有一些手段来证明服务器 B 是安全和可信的。下面就来讨论这一点。

生产电脑操作系统的厂商为了方便用户，把当前获得公众信任的许多主流认证中心 CA 的根证书，都已内置在其操作系统中。这些根证书上都有认证中心 CA 的公钥 PK_{CA} ，而且根证书都用 CA 的私钥 SK_{CA} 进行了自签名（防止伪造）。用户为了验证要访问的服务器是否安全和可信，只要打开电脑中的浏览器（操作系统自带的或用户自己装上的），就可查到操作系统收藏的某个根认证中心的根 CA 证书，并可以利用证书上的公钥 PK_{CA} 对 B 的证书进行验证。若服务器 B 的证书是证书链上的某个中间 CA 签发的，那么浏览器 A 也可用类似方法验证 B 的证书的真实性。

由于浏览器与服务器的通信方式就是以前讲过的“客户-服务器方式”，因此下面就用客户代表浏览器。

如图 7-21 所示，在客户与服务器双方已经建立了 TCP 连接后，就可开始执行协议 TLS。根据 RFC 8446，这里主要有两个阶段，即握手阶段和会话阶段。在握手阶段，TLS 使用其中的握手协议，而在会话阶段，TLS 使用其中的记录协议。下面讨论协议 TLS 的要点。

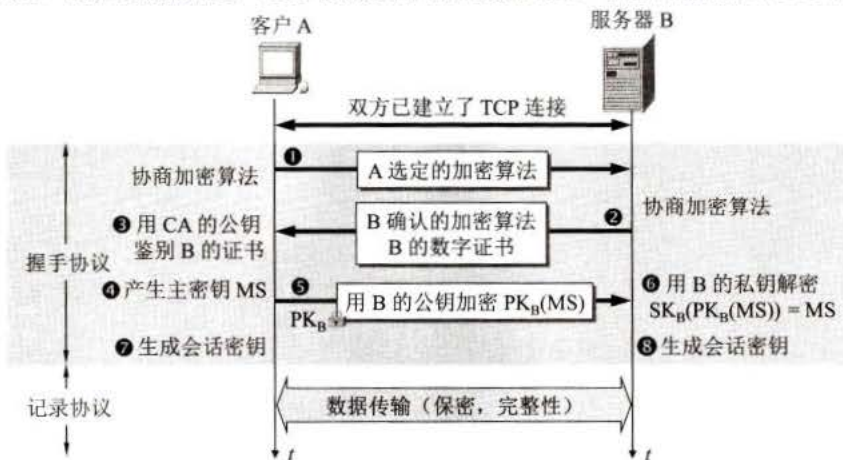


图 7-21 TLS 建立安全会话的工作原理

我们先介绍协议 TLS 的握手阶段。握手阶段要验证服务器是安全可信的，同时生成在后面的会话阶段所需的共享密钥，以保证双方交换的数据的私密性和完整性。这里要提醒读者，在刚开始执行协议 TLS 时，通信双方的信道是不安全的。因此要弄清：(1) 双方怎样通过不安全的信道得到会话时所需的共享密钥。这里没有采用密钥分发中心 KDC 来分配密钥，而是采用自己生成共享密钥的方法。(2) 用什么方法保证所传送数据的机密性与完整性。

(1) 协商加密算法 ①客户 A 向服务器 B 发送自己选定的加密算法（包括密钥交换算法）。②服务器 B 从中确认自己所支持的算法，同时把自己的 CA 数字证书发送给 A。这里要说明一下，从 TLS 1.0 更新到 1.1 和 1.2 版本时，每一次更新都增加了当时认为是更加安全可靠的加密算法。为了协议的向后兼容，对老版本中的不太安全的数十种算法也都保留下来了。这就造成协商过程非常耗时，需要花费 2 倍 RTT 的时间（通常记为 2-RTT）。因此最新的 TLS 1.3 版本把陈旧的很多种算法统统取消（例如 MD5, SHA-1, DES, 3DES 等），只留下几种最安全的算法。客户不是把自己所有的加密算法都告诉服务器，供服务器来挑选，而是猜测服务器可能愿意使用什么加密算法，把自己选定的加密算法直接发送给服务器，让服务器来确认。这就把“协商”时间缩短为 1-RTT。

(2) 服务器鉴别 ③客户 A 用数字证书中 CA 的公钥对数字证书进行验证鉴别。

(3) 生成主密钥 ④客户 A 按照双方确定的密钥交换算法生成主密钥 MS (Master Secret)。⑤客户 A 用 B 的公钥 PK_B 对主密钥 MS 加密，得出加密的主密钥 $PK_B(MS)$ ，发送给服务器 B。请注意，在有关 TLS 的文档中，密钥一词使用的是 Secret，而不是 Key。

(4) 服务器 B 用自己的私钥把主密钥解密出来： $SK_B(PK_B(MS)) = MS$ 。这样，客户 A 和服务器 B 都拥有了为后面的数据传输使用的共同的主密钥 MS。

(5) 为了使双方的通信更加安全，客户 A 和服务器 B 最好使用不同的密钥。于是主密钥被分割成 4 个不同的密钥，这就是图 7-21 中的⑦和⑧：生成会话密钥。在这以后，每一方都拥有这样 4 个密钥（请注意，这些都是对称密钥，即加密和解密用的是同一个密钥）：

- 客户 A 发送数据时使用的会话密钥 K_A
- 客户 A 发送数据时使用的 MAC 密钥 M_A
- 服务器 B 发送数据时使用的会话密钥 K_B
- 服务器 B 发送数据时使用的 MAC 密钥 M_B

会话密钥不使用非对称密钥，因为对称密钥的运行速度快得多（相差 3 个数量级）。

下面讨论协议 TLS 的会话阶段。会话阶段要保证传送数据的机密性和完整性。

客户或服务器在发送数据时，都把长的数据划分为较小的数据块，叫作记录(record)。然后对每一个记录进行鉴别运算和加密运算。为了防止入侵者截取传输中的记录，或颠倒记录的前后顺序，TLS 的记录协议对每一个记录按发送顺序赋予序号，把每一方发送的第一个记录作为 0 号记录。发送下一个记录时序号就加 1，但序号最大值不得超过 $2^{64} - 1$ ，且不允许序号绕回。然而此序号并非写在记录之中，而是在进行散列运算时，把序号包含进去。例如，当客户 A 向服务器 B 发送一个明文记录时，客户 A 先把 MAC 密钥 M_A 和该记录当前的序号一起拼接在此明文记录之后，然后进行散列运算，得出 MAC。再把得出的 MAC 和明文记录拼接起来，用会话密钥 K_A 进行加密，发送给服务器 B。B 使用同样的会话密钥 K_A 进行解密，然后分离出明文记录和 MAC。B 再把同样的 MAC 密钥 M_A 和该记录应有的序号拼接在此明文记录之后，进行散列运算，看得出的结果与前面得出的 MAC 值是否一致，以鉴别收到的明文记录的完整性（内容和顺序均无误）。上述对记录加密的方法称为 AEAD

(Authenticated Encryption with Associated Data), 即带关联数据的鉴别加密。

实际上, 客户 A 所发送的加密的记录的前面, 还必须添加三个不加密的字段, 图 7-22 给出了这三个字段的位置。类型字段指明所传送的记录是握手阶段的报文, 还是应用程序传送的报文, 或最后要关闭 TLS 连接的报文 (下一小节将要解释)。长度字段给出的字节数可用来从 TCP 报文中提取 TLS 记录。

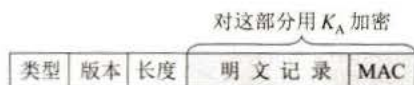


图 7-22 TLS 传送的记录格式

2. 协议 TLS 必须包含的措施

以上介绍的只是协议 TLS 的要点。但若仅仅是这样, 还不能提供足够的安全。因此, 对前面图 7-21 所示的双方的握手阶段, 需要补充一些措施。

(1) 在客户 A 向服务器 B 发送自己选定的加密算法 (包括密钥交换算法) 时, 还要向服务器 B 发送客户的不重数。服务器 B 从中确认自己所支持的算法, 同时把自己的 CA 数字证书和服务器的不重数发送给客户 A。

(2) **生成预主密钥** 客户 A 验证了服务器 B 的数字证书后, 生成为下一步生成主密钥使用的预主密钥 PMS (Pre-Master Secret), 并用 B 的公钥 PK_B 对预主密钥 PMS 加密, 把加密的预主密钥 $PK_B(PMS)$ 发送给服务器 B。B 用其私钥 SK_B 进行解密, 得出预主密钥 PMS。这样, 客户 A 和服务器 B 都拥有了为后面的数据传输使用的共同的预主密钥 PMS。

(3) **生成主密钥** 客户 A 和服务器 B 各自使用同样的 (已商定的) 算法, 使用预主密钥 PMS 以及客户的不重数和服务器的不重数, 生成主密钥 MS。然后再将其划分为 4 个密钥。于是 A 和 B 各拥有相同的 4 个密钥 (每一方在发送数据时使用的会话密钥和 MAC 密钥)。

(4) 客户 A 向服务器 B 发送的全部握手阶段报文的 MAC。

(5) 服务器 B 向客户 A 发送的全部握手阶段报文的 MAC。

上述最后的(4)和(5)的作用是这样的。在 A 向 B 发送加密的预主密钥之前的握手信息是没有加密的明文, 因此可能受到入侵者的篡改。现在 A 和 B 都各自对全部握手阶段的报文计算了散列值 MAC。如果入侵者篡改了处在传输过程中的某个报文, 那么上面(4)和(5)所得出的 MAC 值必然不一致。这样 A 或 B 就可以立即中止当前的连接。

在(1)中客户和服务器各产生一个仅使用一次的不重数, 其目的是为了防止“重放攻击”。设想在 A 和 B 之间有一个入侵者, 他截获了 A 和 B 交互的全部报文。虽然他未能解密 A 和 B 交互的具体内容, 但他可以在以后的某日, 重新按照原来的顺序依次发送给 B。如果没有使用上述的不重数, 那么 B 无法发现这是入侵者重放旧的报文。B 也将和前次的握手过程一样, 向 A 发回报文 (实际上是发给了中间人入侵者)。这样造成的后果是很严重的。但使用了不重数以后, 在下一个 TCP 连接中, 客户 A 必须使用另一个不同的不重数。这样就有效地防止了重放攻击。

前面曾提到在关闭 TLS 连接之前, A 或 B 应当先发送关闭 TLS 的记录, 目的是防止入侵者的截断攻击(truncation attack)。所谓截断攻击就是在 A 和 B 正在进行会话时, 入侵者突然发送 TCP 的 FIN 报文段来关闭 TCP 连接。但如果 A 或 B 没有事先发送一个要关闭 TLS

的记录,那么 A 或 B 见到 TCP 的 FIN 报文段时,就知道这是入侵者的截断攻击了。入侵者无法伪造关闭 TLS 的记录,因为虽然记录前面的三个字段都是明文,但每个记录的内容是加密的,并有 MAC 保证其完整性的。

在 TLS 1.3 中使用了更加安全的椭圆曲线密码 ECC (Elliptic Curve Cryptography)与 AES,使运算速度比旧的 1.2 版本有了很大的提高。TLS 1.3 还添加了 0-RTT 的功能。这就是说,如果客户之前连接过某服务器,TLS 1.3 通过储存先前会话的秘密信息,不需要经过 1-RTT 的握手过程,仅需 0-RTT 即可开始会话阶段,这样就更加提高了 TLS 的效率。当然,这样做必须要防止可能发生的重放攻击。

7.5.3 应用层安全协议

限于篇幅,我们在这一节仅讨论应用层中有关电子邮件的安全协议。

电子邮件在传送过程中可能要经过许多路由器,其中的任何一个路由器都有可能对转发的邮件进行阅读。从这个意义上讲,电子邮件是没有什么隐私可言的。

电子邮件这种网络应用也有其很特殊的地方,这就是发送电子邮件是个即时的行为。这种行为在本质上与我们前两节所讨论的不同。当我们使用 IPSec 或 SSL 时,我们假设双方在相互之间建立起一个会话并双向地交换数据。而在电子邮件中没有会话存在。当 A 向 B 发送一个电子邮件时,A 和 B 并不会为此而建立任何会话。而在此后的某个时间,如果 B 读取了该邮件,他有可能会、也有可能不会回复这个邮件。可见我们所讨论的是单向报文的
安全问题。

如果说电子邮件是即时的行为,那么发送方与接收方如何才能就用于电子邮件安全的加密算法达成一致意见呢?如果双方之间不存在会话,不存在协商加密/解密所使用的算法,那么接收方如何知道发送方选择了哪种算法呢?

要解决这个问题,电子邮件的安全协议就应当为每种加密操作定义相应的算法,以便用户在其系统中使用。A 必须要把使用的算法的名称(或标识)包含在电子邮件中。例如,A 可以选择用 AES 进行加密/解密,并选择用 SHA-1 作为报文摘要算法。当 A 向 B 发送电子邮件时,就在自己的邮件中包含与 AES 和 SHA-1 相对应的标识。B 在接收到该邮件后,首先要提取这些标识,然后就能知道在解密和报文摘要运算时应当分别使用哪种算法了。

加密算法在使用加密密钥时也存在同样的问题。如果没有协商过程,通信的双方如何在彼此之间知道所使用的密钥?目前的电子邮件安全协议要求使用对称密钥算法进行加密和解密,并且这个一次性的密钥要跟随报文一起发送。发信人 A 可以生成一个密钥并把它与报文一起发送给 B。为了保护密钥不被外人截获,这个密钥需要用收信人 B 的公钥进行加密。总之,这个密钥本身也要被加密。

还有一个问题也需要考虑。很显然,要实现电子邮件的安全就必须使用某些公钥算法。例如,我们需要对密钥加密或者对邮件签名。为了对密钥进行加密,发信人 A 就需要收信人 B 的公钥,同样为了验证被签名的报文,收信人 B 也需要发信人 A 的公钥。因此,为了发送一个具有鉴别和保密的报文,就需要用到两个公钥。但是 A 如何才能确认 B 的公钥,B 又如何才能确认 A 的公钥呢?不同的电子邮件安全协议有不同的方法来验证密钥。

下面我们介绍在应用层为电子邮件提供安全服务的协议 PGP。

PGP (Pretty Good Privacy)是 Zimmermann 于 1995 年开发的。它是一个完整的电子邮件安全软件包,包括加密、鉴别、电子签名和压缩等技术。PGP 并没有使用什么新的概念,

它只是把现有的一些加密算法（如 RSA 公钥加密算法或 MD5 报文摘要算法）综合在一起而已。由于包括源程序的整个软件包可以从互联网免费下载[W-PGP]，因此 PGP 在 MS-DOS/Windows 以及 UNIX 等平台上得到了广泛的应用。现在 PGP 的网站以每个月百万页的规模，为一百多个国家的用户提供服务。

后来 PGP 公司与 Zimmermann 同意 IETF 制定 PGP 的公开互联网标准 OpenPGP。2007 年 IETF 发布了 OpenPGP 的建议标准[RFC 4880]。

PGP 的工作原理并不复杂。它提供电子邮件的安全性、发送方鉴别和报文完整性。

假定 A 向 B 发送电子邮件明文 X ，现在用 PGP 进行加密。A 有三个密钥：自己的私钥 SK_A ，B 的公钥 PK_B 和自己生成的一次性密钥 K 。B 有两个密钥：自己的私钥 SK_B 和 A 的公钥 PK_A 。

A 需要做以下几件事（如图 7-23 所示）。

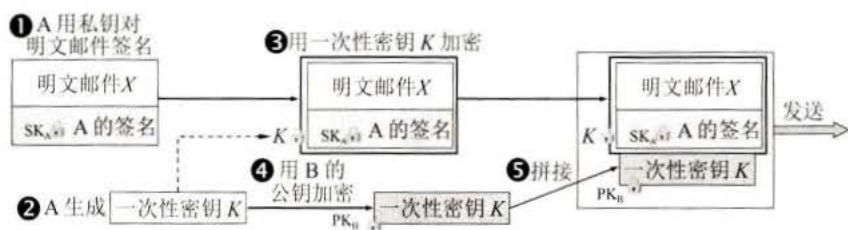


图 7-23 在发送方 A 的 PGP 处理过程

- ① 用 A 的私钥 SK_A 对明文邮件 X 进行签名。把签名拼接在明文邮件 X 后面。
- ② 利用随机数 A 生成一次性密钥 K （共享的对称密钥）。
- ③ 用 A 生成的一次性密钥 K 对已签名的邮件加密。
- ④ 用 B 的公钥 PK_B 对 A 生成的一次性密钥 K 进行加密。
- ⑤ 把已加密的一次性密钥和已加密的签名邮件，拼接在一起发送给 B。

请注意，图 7-23 中三个“加密”的作用是不同的。第一次加密是用 A 的私钥 SK_A 对明文邮件的报文摘要进行加密，即进行数字签名，目的是保证邮件的完整性。第二次加密是用 A 生成的一次性密钥 K 对已签名的邮件加密，目的是保证邮件的机密性。第三次加密是用 B 的公钥 PK_B 对 A 的一次性密钥 K 加密，目的是保证对称密钥 K 的机密性。

B 收到 A 发过来的报文后要做以下几件事（建议读者自行画出相应的图，这里从略）：

(1) 在文档 RFC 4880 中，对加密邮件的各种格式（如仅加密但不鉴别，或仅鉴别但不加密，或加密加上鉴别），均有详细的规定。因此 B 可以根据邮件的种类，准确地把已加密的一次性密钥和已加密的签名报文分离开。

(2) 用 B 私钥 SK_B 解出一次性密钥 K （这是对称密钥，加密和解密都需要各使用一次）。

(3) 用导出的一次性密钥 K 对加密的签名邮件进行解密，分离出明文邮件 X 和 A 的数字签名。

(4) 用 B 手中的 A 的公钥 PK_A 对 A 的数字签名进行解密。然后即可接着验证邮件的完整性，具体的做法与前面图 7-9 所述的相似，这里不再重复。

在 PGP 中，发件方和收件方是如何获得对方的公钥呢？当然，最安全的办法是双方面对面直接交换公钥，但在大多数情况下这并不现实。因此可以通过认证中心 CA 签发的证书来验证公钥持有者的合法身份。然而在 PGP 中不要求使用 CA，而是允许用一种第三方签署的方式来解决该问题。例如，如果用户 A 和用户 B 分别和第三方 C 已经确认对方拥有的公

钥属实, 则 C 可以用其私钥分别对 A 和 B 的公钥进行签名, 为这两个公钥进行担保。当 A 得到一个经 C 签名的 B 的公钥时, 可以用已确认的 C 的公钥对 B 的公钥进行鉴别。不过, 用户发布其公钥的最常见的方式还是把公钥发布在他们的个人网页上, 或仅仅通过电子邮件进行分发。

PGP 很难被攻破。因此在目前可以认为 PGP 是足够安全的。

7.6 系统安全: 防火墙与入侵检测

恶意用户或软件通过网络对计算机系统的入侵或攻击已成为当今计算机安全最严重的威胁之一。用户入侵包括利用系统漏洞进行未授权登录, 或者授权用户非法获取更高级别权限。软件入侵方式包括通过网络传播病毒、蠕虫和特洛伊木马。此外还包括阻止合法用户正常使用服务的拒绝服务攻击, 等等。而前面讨论的所有安全机制都不能有效解决以上安全问题。例如, 加密技术并不能阻止植入了“特洛伊木马”的计算机系统通过网络向攻击者泄漏秘密信息。

7.6.1 防火墙

防火墙(firewall)作为一种访问控制技术, 通过严格控制进出网络边界的分组, 禁止任何不必要的通信, 从而减少潜在入侵的发生, 尽可能降低这类安全威胁所带来的安全风险。由于防火墙不可能阻止所有入侵行为, 作为系统防御的第二道防线, **入侵检测系统 IDS (Intrusion Detection System)**通过对进入网络的分组进行深度分析与检测发现疑似入侵行为的网络活动, 并进行报警以便进一步采取相应措施。

防火墙是一种特殊编程的路由器, 安装在一个网点和网络的其余部分之间, 目的是实施访问控制策略。这个访问控制策略是由使用防火墙的单位自行制定的。这种安全策略应当最适合本单位的需要。图 7-24 指出防火墙位于互联网和内部网络之间。互联网这边是防火墙的外面, 而内部网络这边是防火墙的里面。一般都把防火墙里面的网络称为“可信的网络”(trusted network)^①, 而把防火墙外面的网络称为“不可信的网络”(untrusted network)。

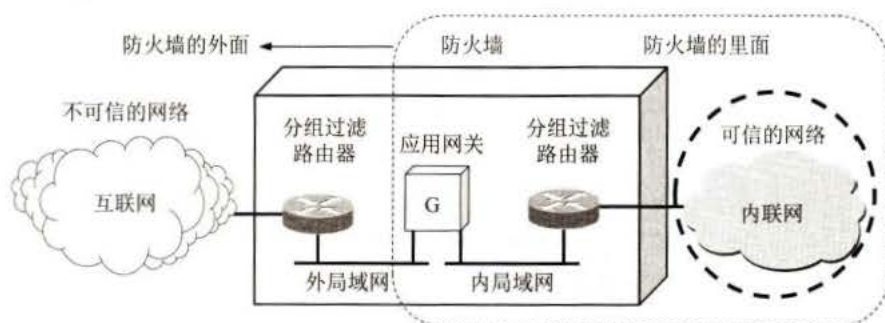


图 7-24 防火墙在互连网络中的位置

^① 注: 2004 年 11 月, 联合国总部建立了“互联网治理工作组 WGIG (Working Group on Internet Governance)”, 来解决互联网的诚信和安全问题。我国在 2006 年 2 月颁布的《国家中长期科学和技术发展规划纲要(2006—2020 年)》中, 提出以发展高可信网络为重点。现在高可信网络已成为研究热点。

防火墙技术一般分为以下两类。

(1) **分组过滤路由器**是一种具有分组过滤功能的路由器，它根据过滤规则对进出内部网络的分组执行转发或者丢弃（即过滤）。过滤规则是基于分组的网络层或运输层首部的信息，例如：源/目的 IP 地址、源/目的端口、协议类型（TCP 或 UDP），等等。我们知道，TCP 的端口号指出了在 TCP 上面的应用层服务。例如，端口号 23 是 TELNET，端口号 119 是新闻网 USENET，等等。所以，如果在分组过滤器中将所有目的端口号为 23 的入分组(incoming packet)都进行阻拦，那么所有外单位用户就不能使用 TELNET 登录到本单位的主机上。同理，如果某公司不愿意其雇员在上班时花费大量时间去看互联网的 USENET 新闻，就可将目的端口号为 119 的出分组(outgoing packet)阻拦住，使其无法发送到互联网。

分组过滤可以是无状态的，即独立地处理每一个分组。也可以是有状态的，即要跟踪每个连接或会话的通信状态，并根据这些状态信息来决定是否转发分组。例如，一个进入到分组过滤路由器的分组，如果其目的端口是某个客户动态分配的，那么该端口显然无法事先包含在规则中。这样的分组被允许通过的唯一条件是：该分组是该端口发出合法请求的一个响应。这样的规则只能通过有状态的检查来实现。

分组过滤路由器的优点是简单高效，且对于用户是透明的，但不能对高层数据进行过滤。例如，不能禁止某个用户对某个特定应用进行某个特定的操作，不能支持应用层用户鉴别等。这些功能需要使用应用网关技术来实现。

(2) **应用网关**也称为**代理服务器(proxy server)**，它在应用层通信中扮演报文中继的角色。一种网络应用需要一个应用网关，例如在上一章 6.4.3 节中“代理服务器”介绍过的万维网缓存就是一种万维网应用的代理服务器。在应用网关中，可以实现基于应用层数据的过滤和高层用户鉴别。

所有进出网络的应用程序报文都必须通过应用网关。当某应用客户进程向服务器发送一份请求报文时，先发送给应用网关，应用网关在应用层打开该报文，查看该请求是否合法（可根据应用层用户标识 ID 或其他应用层信息来确定）。如果请求合法，应用网关以客户进程的身份将请求报文转发给原始服务器。如果不合法，报文则被丢弃。例如，一个邮件网关在检查每一个邮件时，会根据邮件地址，或邮件的其他首部，甚至是报文的内容（如，有没有“导弹”“核弹头”等关键词）来确定该邮件能否通过防火墙。

应用网关也有一些缺点。首先，每种应用都需要一个不同的应用网关（可以运行在同一台主机上）。其次，在应用层转发和处理报文，处理负担较重。另外，对应用程序不透明，需要在应用程序客户端配置应用网关地址。

通常可将这两种技术结合使用，图 7-24 所画的防火墙就同时具有这两种技术。它包括两个分组过滤路由器和一个应用网关，它们通过两个局域网连接在一起。

7.6.2 入侵检测系统

防火墙试图在入侵行为发生之前阻止所有可疑的通信。但事实是不可能阻止所有的入侵行为，有必要采取措施在入侵已经开始，但还没有造成危害或在造成更大危害前，及时检测到入侵，以便尽快阻止入侵，把危害降低到最小。**入侵检测系统 IDS**正是这样一种技术。IDS 对进入网络的分组执行深度分组检查，当观察到可疑分组时，向网络管理员发出告警或执行阻断操作（由于 IDS 的“误报”率通常较高，多数情况不执行自动阻断）。IDS 能用于检测多种网络攻击，包括网络映射、端口扫描、DoS 攻击、蠕虫和病毒、系统漏洞攻击等。

入侵检测方法一般可以分为基于特征的入侵检测和基于异常的入侵检测两种。

基于特征的 IDS 维护一个所有已知攻击标志性特征的数据库。每个特征是一个与某种入侵活动相关联的规则集，这些规则可能基于单个分组的首部字段值或数据中特定比特串，或者与一系列分组有关。当发现有与某种攻击特征匹配的分组或分组序列时，则认为可能检测到某种入侵行为。这些特征和规则通常由网络安全专家生成，机构的网络管理员定制并将其加入到数据库中。

基于特征的 IDS 只能检测已知攻击，对于未知攻击则束手无策。基于异常的 IDS 通过观察正常运行的网络流量，学习正常流量的统计特性和规律，当检测到网络中流量的某种统计规律不符合正常情况时，则认为可能发生了入侵行为。例如，当攻击者在对内网主机进行 ping 搜索时，或导致 ICMP ping 报文突然大量增加，与正常的统计规律有明显不同。但区分正常流和统计异常流是一件非常困难的事情。至今为止，大多数部署的 IDS 主要是基于特征的，尽管某些 IDS 包括了某些基于异常的特性。

不论采用什么检测技术都存在“漏报”和“误报”情况。如果“漏报”率比较高，则只能检测到少量的入侵，给人以安全的假象。对于特定 IDS，可以通过调整某些阈值来降低“漏报”率，但同时会增大“误报”率。“误报”率太大会导致大量虚假警报，网络管理员需要花费大量时间分析报警信息，甚至会因为虚假警报太多而对报警“视而不见”，使 IDS 形同虚设。

7.7 一些未来的发展方向

本章介绍了网络安全的主要概念。网络安全是一个很大的领域，无法在这进行深入的探讨。对于有志于这一领域的读者，可在下面几个方向做进一步的研究：

(1) 椭圆曲线密码 ECC 目前椭圆曲线密码已在 TLS 1.3 的握手协议中占据非常重要的地位。此外，在电子护照和金融系统中也大量使用椭圆曲线密码系统。在互联网上已有许多关于椭圆曲线密码的资料。限于篇幅，无法在本书中进行介绍。

(2) 移动安全(Mobile Security) 移动通信带来的广泛应用（如移动支付，Mobile Payment）向网络安全提出了更高的要求。

(3) 量子密码(Quantum Cryptography) 量子计算机的到来将使得目前许多使用中的密码技术无效，后量子密码学(Post-Quantum Cryptography)的研究方兴未艾。

(4) 商密九号算法 SM9 为了降低公钥和证书管理的复杂性，早在三十多年前提出的标识密码(Identity-Based Cryptography)，现在又被重视。标识密码把用户的标识（如手机号码）作为公钥，使得安全系统变得易于部署和管理。2008 年标识密码算法正式获得我国密码管理局签发为商密九号算法 SM9。此算法不需要申请数字证书，适用于互联网应用的各種新兴应用的安全保障，其应用前景值得关注。

本章的重要概念

- 计算机网络上的通信面临的威胁可分为两大类，即被动攻击（如截获）和主动攻击（如中断、篡改、伪造）。主动攻击的类型有更改报文流、拒绝服务、伪造初始化、恶意程序（病毒、蠕虫、木马、逻辑炸弹、后门入侵、流氓软件）等。
- 计算机网络安全主要有以下一些内容：机密性、端点鉴别、信息的完整性、运行的

安全性和访问控制。

- 密码编码学是密码体制的设计学，而密码分析学则是在未知密钥的情况下从密文推演出明文或密钥的技术。密码编码学与密码分析学合起来即为密码学。
- 如果不论截取者获得了多少密文，都无法唯一地确定出对应的明文，则这一密码体制称为无条件安全的（或理论上是不可破的）。在无任何限制的条件下，目前几乎所有实用的密码体制均是可破的。如果一个密码体制中的密码不能在一定时间内被可以使用的计算资源破译，则这一密码体制称为在计算上是安全的。
- 对称密钥密码体制是加密密钥与解密密钥相同的密码体制（如数据加密标准 DES 和高级加密标准 AES）。这种加密的机密性仅取决于对密钥的保密，而算法是公开的。
- 公钥密码体制（又称为公开密钥密码体制）使用不同的加密密钥与解密密钥。加密密钥（即公钥）是向公众公开的，而解密密钥（即私钥或密钥）则是需要保密的。加密算法和解密算法也都是公开的。
- 目前最著名的公钥密码体制是 RSA 体制，它是基于数论中的大数分解问题的体制。
- 任何加密方法的安全性取决于密钥的长度，以及攻破密文所需的计算量，而不是简单地取决于加密的体制（公钥密码体制或传统加密体制）。
- 数字签名必须保证能够实现以下三点功能：(1)报文鉴别，即接收者能够核实发送者对报文的签名；(2)报文的完整性，即接收者确信所收到的数据和发送者发送的完全一样而没有被篡改过；(3)不可否认，即发送者事后不能抵赖对报文的签名。
- 鉴别是要验证通信的对方的确是自己所要通信的对象，而不是其他的冒充者。鉴别与授权是不同的概念。
- 报文摘要 MD 曾是一种鉴别报文的常用方法，后来有了更加安全的 SHA-1。但目前最为安全的是 SHA-2 和 SHA-3。
- 密钥管理包括：密钥的产生、分配、注入、验证和使用。密钥分配（或密钥分发）是密钥管理中最大的问题。密钥必须通过最安全的通路进行分配。密钥分配中心 KDC 是一种常用的密钥分配方式。
- 认证中心 CA 是签发数字证书的实体，也是可信的第三方。CA 把公钥与其对应的实体（人或机器）进行绑定和写入证书，并对证书进行数字签名。任何人都可从可信的地方获得认证中心 CA 的公钥来鉴别数字证书的真伪。
- 为了方便地签发数字证书，根 CA 可以有下面的多级的中间 CA，负责给用户签发数字证书。这样就构成了信任链和证书链。
- 在网络层可使用 IPsec 协议族，IPsec 包括鉴别首部协议 AH 和封装安全有效载荷协议 ESP。AH 协议提供源点鉴别和数据完整性，但不能保密。而 ESP 协议提供源点鉴别、数据完整性和保密。IPsec 支持 IPv4 和 IPv6。在 IPv6 中，AH 和 ESP 都是扩展首部的一部分。IPsec 数据报的工作方式有运输方式和隧道方式两种。
- 运输层的安全协议曾经有 SSL（安全套接字层）和 TLS（运输层安全）。但 SSL 已被淘汰。目前使用的最新版本是 TLS 1.3。TLS 不仅对服务器的安全性进行鉴别，而且对浏览器与服务器的所有会话记录进行加密，并保证了所传送的报文的完整性。
- PGP 是一个完整的电子邮件安全软件包，包括加密、鉴别、电子签名和压缩等技术。PGP 并未使用新概念，只是把现有的一些加密算法（如 RSA 公钥加密算法或

SHA 报文摘要算法) 综合使用而已。

- 防火墙是一种特殊编程的路由器, 安装在一个网点和网络的其余部分之间, 目的是实施访问控制策略。防火墙里面的网络称为“可信的网络”, 而把防火墙外面的网络称为“不可信的网络”。防火墙的功能有两个: 一个是阻止 (主要的), 另一个是允许。
- 防火墙技术分为: 网络级防火墙, 用来防止整个网络出现外来非法的入侵 (属于这类的有分组过滤和授权服务器); 应用级防火墙, 用来进行访问控制 (用应用网关或代理服务器来区分各种应用)。
- 入侵检测系统 IDS 是在入侵已经开始, 但还没有造成危害或在造成更大危害前, 及时检测到入侵, 以便尽快阻止入侵, 把危害降低到最小。

习题

7-01 计算机网络都面临哪几种威胁? 主动攻击和被动攻击的区别是什么? 对于计算机网络, 其安全措施都有哪些?

7-02 试解释以下名词: (1)拒绝服务; (2)访问控制; (3)流量分析; (4)恶意程序。

7-03 为什么说计算机网络的安全不仅仅局限于机密性? 试举例说明, 仅具有机密性的计算机网络不一定是安全的。

7-04 密码编码学、密码分析学和密码学都有哪些区别?

7-05 “无条件安全的密码体制”和“在计算上是安全的密码体制”有什么区别?

7-06 试破译下面的密文诗。加密采用替代密码。这种密码是把 26 个字母 (从 a 到 z) 中的每一个用其他某个字母替代 (注意, 不是按序替代)。密文中无标点符号。空格未加密。

kfd ktbd fzm eubd kfd pzyiom mztz ku kzyg ur bzha kfthcm ur mfudm zhx
mftnm zhx mdzythc pzq ur ezsszcdm zhx gthcm zhx pfa kfd mdz tm sutythc
fuk zhx pfdkfdi ntem fzld pthcm sok pztk z stk kfd uamkdim eitdx sdruidd
pd fzld uoi efzk rui mubd ur om zid uok ur sidzkd zhx zyy ur om zid rzk
hu foiaa mztz kfd ezindhkdi kfda kfzhgdx fth boef rui kfzk

7-07 对称密钥体制与公钥密码体制的特点各是什么? 各有何优缺点?

7-08 为什么密钥分配是一个非常重要但又十分复杂的问题? 试举出一种密钥分配的方法。

7-09 公钥密码体制下的加密和解密过程是怎样的? 为什么公钥可以公开? 如果不公开是否可以提高安全性?

7-10 试述数字签名的原理。

7-11 为什么需要进行报文鉴别? 鉴别和保密、授权有什么不同? 报文鉴别和实体鉴别有什么区别?

7-12 试分别举例说明以下情况: (1)既需要保密, 也需要鉴别; (2)需要保密, 但不需要鉴别; (3)不需要保密, 但需要鉴别。

7-13 A 和 B 共同持有一个只有他们二人知道的密钥 (使用对称密码)。A 收到了用这个密钥加密的一份报文。A 能否出示此报文给第三方, 使 B 不能否认发送了此报文?

7-14 将图 7-5 所示的具有机密性的签名与使用报文鉴别码相比较, 哪一种方法更有利于进行鉴别?

- 7-15 试述实现报文鉴别和实体鉴别的方法。
- 7-16 结合第 5 章图 5-6 计算 UDP 的检验和的例子,说明这种检验和不能用来鉴别报文。
- 7-17 报文的机密性与完整性有何区别?什么是 MD5?
- 7-18 什么是重放攻击?怎样防止重放攻击?
- 7-19 图 7-11 的鉴别过程也有可能被骗子利用。假定 A 发送报文和 B 联系,但不巧被骗子 P 截获了,于是 P 发送报文给 A:“我是 B”。接着, A 就发送图 7-11 中的第一个报文“A, R_A ”,这里 R_A 是不重数。本来, P 必须也发给 A 另一个不重数,以及发回使用两人共同拥有的密钥 K_{AB} 加密的 R_A ,即 $K_{AB}(R_A)$ 。但 P 根本不知道 K_{AB} ,只好就发送同样的 R_A 作为自己的不重数。A 收到 R_A 后,发给 P 报文“ $K_{AB}(R_A)$ ”,P 仍然不知道密钥 K_{AB} ,也照样发回报文“ $K_{AB}(R_A)$ ”。接着 A 就把一些报文发送给 P 了。虽然 P 不知道密钥 K_{AB} ,但可以慢慢设法攻破。试问 A 能否避免这样的错误?
- 7-20 什么是“中间人攻击”?怎样防止这种攻击?
- 7-21 试讨论 Kerberos 协议的优缺点。
- 7-22 互联网的网络层安全协议族 IPsec 都包含哪些主要协议?
- 7-23 用户 A 和 B 使用 IPsec 进行通信。A 需要向 B 接连发送 6 个分组。是否需要在每发送一个分组之前,都先建立一次安全关联 SA?
- 7-24 在图 7-18(b)中,公司总部和业务员之间先建立了 TCP 连接,然后使用 IPsec 进行通信。假定有一个 TCP 报文段丢失了。后来在重传该序号的报文段时,相应的 IPsec 安全数据报是否也要使用同样的 IPsec 序号呢?
- 7-25 试简述协议 TLS 的工作过程。
- 7-26 在图 7-21 中,假定在第一步,顾客(客户 A)发送报文给经销商(服务器 B)时,误将报文发送到一个骗子处,而骗子就接着冒充经销商继续下面的步骤。试问在报文交互到第几个步骤时,顾客可以发现对方并不是真正的经销商?
- 7-27 电子邮件的安全协议 PGP 主要都包含哪些措施?
- 7-28 试述防火墙的工作原理和所提供的功能。什么叫作网络级防火墙和应用级防火墙?

第8章 互联网上的音频/视频服务

本章首先对互联网提供音频/视频服务进行概述。然后介绍流式音频/视频中的媒体服务器和实时流式协议 RTSP, 并以 IP 电话为例介绍交互式音频/视频所使用的一些协议, 如实时运输协议 RTP、实时传送控制协议 RTCP、H.323 以及会话发起协议 SIP。接着讨论改进“尽最大努力交付”服务的一些措施, 包括怎样使互联网能够提高服务质量, 并介绍综合服务 IntServ、资源预留协议 RSVP 和区分服务 DiffServ 的要点。

本章最重要的内容是:

- (1) 多媒体信息的特点(如时延和时延抖动, 播放时延等)。
- (2) 流媒体的概念。
- (3) IP 电话使用的几种协议。
- (4) 改进“尽最大努力交付”服务的几种方法。

8.1 概述

计算机网络最初是为传送数据设计的。互联网 IP 层提供的“尽最大努力交付”服务以及每一个分组独立交付的策略, 对传送数据信息十分合适。互联网使用的 TCP 协议可以很好地解决 IP 层不能提供可靠交付这一问题。

然而技术的进步使许多用户开始利用互联网传送音频/视频信息。在许多情况下, 这种音频/视频常称为**多媒体信息**^①。本来电路交换的公用电话网传送话音和多媒体信息早已是成熟的技术。例如视频会议(又称为电视会议)原先是使用电路交换的公用电话网。使用电路交换的好处是: 一旦连接建立了(也就是只要拨通了电话), 各种信号在电话线路上的**传输质量就有保证**。但使用公用电话网的缺点是**价格太高**。因此要想办法改用互联网。

多媒体信息(包括声音和图像信息)与不包括声音和图像的数据信息有很大的区别, 其中最主要的两个特点如下。

第一, **多媒体信息的信息量往往很大**。

含有音频或视频的多媒体信息的信息量一般都很大, 下面是简单的说明。

对于电话的声音信息, 如采用标准的 PCM 编码(8 kHz 速率采样), 而每一个采样脉冲用 8 位编码, 则得出的声音信号的数据率就是 64 kbit/s。对于高质量的立体声音乐 CD 信息, 虽然它也使用 PCM 编码, 但其采样速率为 44.1 kHz, 而每一个采样脉冲用 16 位编码, 因此这种双声道立体声音乐信号的数据率超过了 1.4 Mbit/s。

① 注: 多媒体信息和传统数据信息不同, 它是指内容上相互关联的文本、图形、图像、声音、动画和活动图像等所形成的复合数据信息。而多媒体业务则应有集成性、交互性和同步性的特点。集成性是指对多媒体信息进行存储、传输、处理、显示的能力, 交互性是指人与多媒体业务系统之间的相互控制能力, 同步性是指在多媒体业务终端上显示的图像、声音和文字是以同步方式工作的。在本章中, 我们经常把音频/视频信息和多媒体信息作为同义词来使用, 虽然它们并不严格地等同。

再看一下数码照片。假定分辨率为 1280×960 (中等质量)。若每个像素用 24 位进行编码, 则一张未经压缩的照片的字节数约合 3.52 MB (这里 $1\text{ B} = 8\text{ bit}$, $1\text{ M} = 2^{20}$)。

活动图像的信息量就更大, 如不压缩的彩色电视信号的数据率超过 250 Mbit/s。

因此在网上传送多媒体信息都无例外地采用各种信息压缩技术。例如在话音压缩方面的标准有: 移动通信的 GSM (13 kbit/s), IP 电话使用的 G.729 (8 kbit/s) 和 G.723.1 (6.4 kbit/s 和 5.3 kbit/s); 在立体声音乐的压缩技术有 MP3 (128 kbit/s 或 112 kbit/s)。在视频信号方面有: VCD 质量的 MPEG 1 (1.5 Mbit/s) 和 DVD 质量的 MPEG 2 (3~6 Mbit/s)。由于多媒体信息压缩技术本身不是计算机网络技术范畴, 本书将不讨论有关数据压缩方面的内容。

第二, 在传输多媒体数据时, 对时延和时延抖动均有较高的要求。

首先要说明的是, “传输多媒体数据” 隐含地表示了 “边传输边播放” 的意思。因为如果是把多媒体音频/视频节目先下载到计算机的硬盘中, 等下载完毕后再去播放, 那么在互联网上传输多媒体数据就没有什么更多的特点值得我们专门来讨论 (仅仅是数据量非常大而已)。设想我们想欣赏网上的某个视频或音频节目。如果必须先花几个小时 (准确的时间事先还不知道) 来下载它, 等下载完毕后才能开始播放, 那么这显然是很不方便的。因此, 今后讨论在互联网上传输多媒体数据时, 都是指含有 “边传输边播放” 的特点。

我们知道, 模拟的多媒体信号只有经过数字化后才能在互联网上传送。就是对模拟信号要经过采样和模数转换变为数字信号, 然后将一定数量的比特组装成分组进行传送。这些分组在发送时的时间间隔都是恒定的, 通常称这样的分组为等时的(isochronous)。这种等时分组进入互联网的速率也是恒定的。但传统的互联网本身是非等时的。这是因为在使用 IP 协议的互联网中, 每一个分组是独立地传送, 因而这些分组在到达接收端时就变成为非等时的。如果我们在接收端对这些以非恒定速率到达的分组边接收边还原, 那么就一定会产生很大的失真。图 8-1 说明了互联网是非等时的这一特点。



图 8-1 互联网是非等时的

要解决这一问题, 可以在接收端设置适当大小的缓存^①, 当缓存中的分组数达到一定的数量后再以恒定速率按顺序将这些分组读出进行还原播放。图 8-2 说明了缓存的作用。

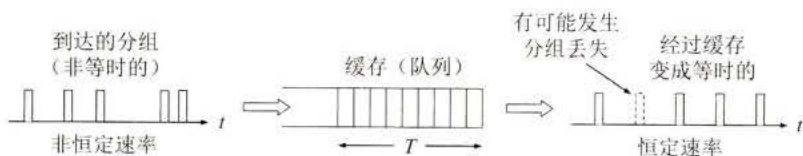


图 8-2 缓存把非等时的分组变换为等时的

从图 8-2 可看出, 缓存实际上就是一个先进先出的队列。图中标明的 T 叫作播放时延, 这就是从最初的分组开始到达缓存算起, 经过时间 T 后就按固定时间间隔把缓存中的分组

^① 注: 请不要和运输层 TCP 的缓存弄混。这里所说的缓存是在应用层的缓存。

按先后顺序依次读出。我们看到，缓存使所有到达的分组都经受了迟延。由于分组以非恒定速率到达，因此早到达的分组在缓存中停留的时间较长，而晚到达的分组在缓存中停留的时间就较短。从缓存中取出分组是按照固定的时钟节拍进行的，因此，到达的非等时的分组，经过缓存后再以恒定速率读出，就变成了等时的分组（但请注意，时延太大的分组就舍弃了），这就在很大程度上消除了时延的抖动。但我们付出的代价是增加了时延。以上所述的概念可以用图 8-3 来说明。

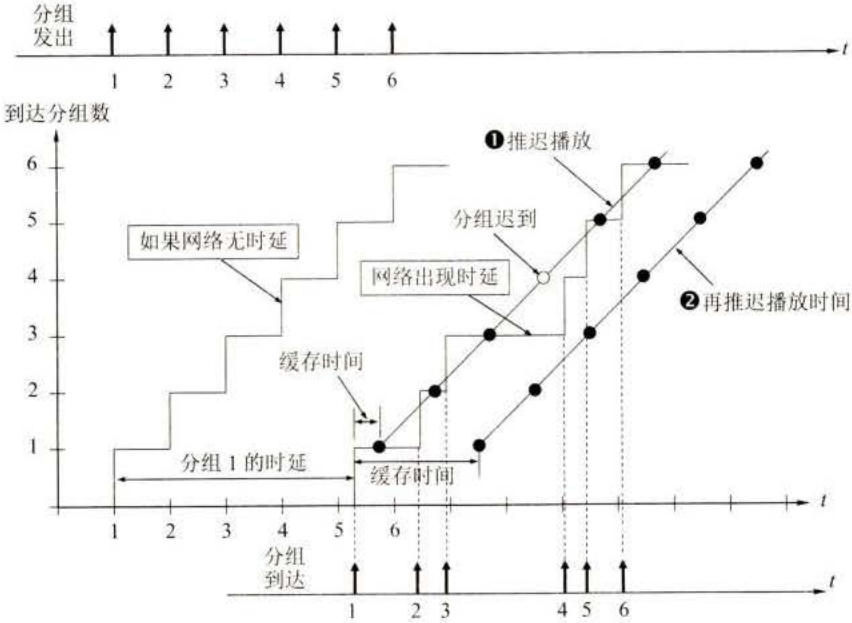


图 8-3 利用缓存得到等时的分组序列

图 8-3 画出了发送端一连发送 6 个等时的分组。如果网络没有时延，那么到达的分组数随时间的变化就如图中最左边的阶梯状的曲线所示。这就是说，只要发送方一发出一个分组，在接收方到达的分组数就立即加 1。但实际的网络使每一个分组经受的时延不同，因此这一串分组在到达接收端时就变成了非等时的，这就使得分组到达的阶梯状曲线向右移动，并且变成不均匀的。图 8-3 标注出了分组 1 的时延。图中给出了两个不同的开始播放时刻。黑色小圆点表示在播放时刻对应的分组已经在缓存中，而空心小圆圈表示在播放时刻对应的分组尚未到达。我们可以看出，即使推迟了播放时间（如图中的❶），也还有可能有某个迟到分组赶不上播放（如图中的空心小圆圈）。如果再推迟播放时间（如图中的❷），则所有的 6 个分组都不会错过播放，但这样做的时延会较大。

然而我们还有一些问题没有讨论。

首先，播放时延 T 应当选为多大？把 T 选择得越大，就可以消除更大的时延抖动，但所有分组经受的平均时延也增大了，而这对某些实时应用（如视频会议）是很不利的。当然这对单向传输的视频节目问题并不太大（如从网上下载一段视频节目，只要耐心多等待一段时间用来将分组放入缓存即可）。如果 T 选择得太小，那么消除时延抖动的效果就较差。因此播放时延 T 的选择必须折中考虑。在传送时延敏感(delay sensitive)的实时数据时，不仅传输时延不能太大，而且时延抖动也必须受到限制。

其次,在互联网上传输实时数据的分组时有可能出现差错或甚至丢失。如果利用 TCP 协议对这些出错或丢失的分组进行重传,那么时延就会大大增加。因此实时数据的传输在运输层就应采用用户数据报协议 UDP 而不使用 TCP 协议。这就是说,对于传送实时数据,我们宁可丢失少量分组(当然不能丢失太多),也不要太晚到达的分组。在连续的音频或视频数据流中,很少量分组的丢失对播放效果的影响并不大(因为这是由人来进行主观评价的),因而是可以容忍的。丢失容忍(loss tolerant)也是实时数据的另一个重要特点。

由于分组的到达可能不按序,但将分组还原和播放时又应当是按序的。因此在发送多媒体分组时还应当给每一个分组加上序号。这表明还应当有相应的协议支持才行。

还有一种情况,就是要使接收端能够将节目中本来就存在的正常的短时间停顿(如话音中的静默期或音乐中出现的几拍停顿)和因某些分组产生的较大延迟造成的“停顿”区分开来。这就需要在每一个分组增加一个时间戳(timestamp),让接收端知道所收到的每一个分组是在什么时间产生的。

有了序号和时间戳,再采用适当的算法,接收端就知道应在什么时间开始播放缓存中收到的分组。这样既可减少分组的丢失率,也可使播放的延迟在人们可容忍的范围之内。

根据以上的讨论可以看出,若想在互联网上传送质量很好的音频/视频数据,就需要设法改造现有的互联网使它能够适应音频/视频数据的传送。

对这个问题,网络界一直有较大的争论,众说纷纭。有人认为,只要大量使用光缆,网络的时延和时延抖动就可以足够小。再加上使用具有大容量高速缓存的高速路由器,在互联网上传送实时数据就不会有问题。也有人认为,必须将互联网改造为能够对端到端的带宽实现预留(reservation),从而根本改变互联网的协议栈——从无连接的网络转变为面向连接的网络。还有人认为,部分改动互联网的协议栈所付出的代价较小,而这也能够使多媒体信息在互联网上的传输质量得到改进。

尽管上述的争论仍在继续,但互联网的一些新的协议也在不断出现。下面我们有选择地讨论与传送音频/视频信息有关的若干问题。

目前互联网提供的音频/视频服务大体上可分为三种类型:

(1) **流式(streaming)存储音频/视频** 这种类型是先把已压缩的录制好的音频/视频文件(如音乐、电影等)存储在服务器上。用户通过互联网下载这样的文件。请注意,用户并不是把文件全部下载完毕后再播放,因为这往往需要很长时间,而用户一般也不大愿意等待太长的时间。流式存储音频/视频文件的特点是能够**边下载边播放**,即在文件下载后不久(例如,一般在缓存中存放最多几十秒)就开始连续播放。请注意,普通光盘中的 DVD 电影文件不是流式视频文件。如果我们打算下载一部光盘中的普通的 DVD 电影,那么你能只能花费很长的时间把整个电影文件全部下载完毕后才能播放。请注意,flow 的译名也是“流”(或“流量”),但意思和 streaming 完全不同。

(2) **流式实况音频/视频** 这种类型和无线电台或电视台的实况广播相似,不同之处是音频/视频节目的**广播**是通过互联网来传送的。流式实况音频/视频是一对多(而不是一对一)的通信。它的特点是:音频/视频节目不是事先录制好和存储在服务器中的,而是在发送方**边录制边发送**(不是录制完毕后再发送)。在接收时也要求能够连续播放。接收方收到节目的时间和节目中事件的发生时间可以认为是同时的(相差仅仅是电磁波的传播时间和很短的信号处理时间)。流式实况音频/视频按理说应当采用多播技术才能提高网络资源的利用率,

但目前实际上还是使用多个独立的单播。

(3) **交互式音频/视频** 这种类型是用户使用互联网和其他人进行实时交互式通信。现在的互联网电话或互联网电视会议就属于这种类型。

请注意,对于流式音频/视频的“下载”,实际上并没有把“下载”的内容存储在硬盘上。因此当“边下载边播放”结束后,在用户的硬盘上没有留下有关播放内容的任何痕迹。播放流式音频/视频的用户,仅仅能够在屏幕上观看播放的内容。用户既不能修改节目内容,也不能把播放的内容存储下来,因此也无法进行转发。这对保护版权非常有利。

不过技术总是在不断进步的,现在已经有了能够存储在网上播放的流式音频/视频文件的软件。

我们现在常见的词汇**流媒体(streaming media)**就是上面所说的流式音频/视频。流媒体最主要的特点就是不是全部都收录下来再开始播放。在国外的一些文献中,常见到 streaming 一词,网上有人译为“串流”或“流播”,但目前还没有找到对 streaming 更好的译名。

限于篇幅,下面简单介绍上面的第一种和第三种音频/视频类型的服务。

8.2 流式存储音频/视频

“流式存储音频/视频”中的“存储”二字,表明这里所讨论的流式音频/视频文件不是实时产生的,而是已经录制好的,通常存储在光盘或硬盘中。不过有时为了简便,往往省略“存储”二字。在讨论从网上下载这种文件之前,我们先回忆一下使用传统的浏览器是怎样从服务器下载已经录制好的音频/视频文件的。图 8-4 说明了下载的三个步骤。

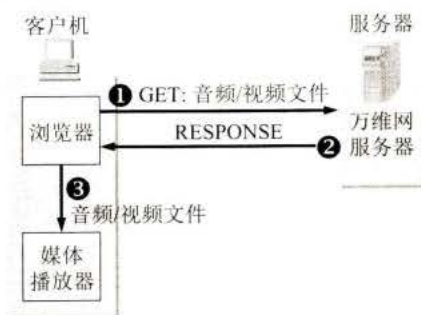


图 8-4 传统的下载文件方法

❶ 用户从客户机(client machine)的浏览器上用 HTTP 协议向服务器请求下载某个音频/视频文件, GET 表示请求下载的 HTTP 报文。请注意, HTTP 使用 TCP 连接。

❷ 服务器如有此文件就发送给浏览器, RESPONSE 表示服务器的 HTTP 响应报文。在响应报文中装有用户所要的音频/视频文件。整个下载过程可能会花费很长的时间。

❸ 当浏览器完全收下这个文件后(所需的时间取决于音频/视频文件的大小),就可以传送给自已机器上的媒体播放器进行解压缩,然后播放。

为什么不能直接在浏览器中播放音频/视频文件呢?这是因为播放器并没有集成在万维网浏览器中。因此,必须使用一个单独的应用程序来播放这种音频/视频节目。这个应用程序通常称为**媒体播放器(media player)**。现在流行的媒体播放器有 Real Networks 的 RealPlayer、微软的 Windows Media Player 和苹果公司的 QuickTime。媒体播放器具有的主要功能是:管

理用户界面、解压缩、消除时延抖动和处理传输带来的差错。

请注意，图 8-4 所示传统的下载文件的方法并没有涉及“流式”（即边下载边播放）的概念。传统的下载方法最大缺点就是历时太长，这往往使下载者不愿继续等待。为此，已经找出了几种改进的措施。

8.2.1 具有元文件的万维网服务器

第一种改进的措施就是在万维网服务器中，除了真正的音频/视频文件外，还增加了一个元文件(metafile)。所谓元文件（请注意，不是源文件）就是一种非常小的文件，它描述或指明其他文件的一些重要信息。这里的元文件保存了有关这个音频/视频文件的信息。图 8-5 说明了使用元文件下载音频/视频文件的几个步骤。



图 8-5 使用具有元文件的万维网服务器

❶ 浏览器用户点击所要看的音频/视频文件的超链，使用 HTTP 的 GET 报文接入到万维网服务器。实际上，这个超链并没有直接指向所请求的音频/视频文件，而是指向一个元文件。这个元文件有实际的音频/视频文件的统一资源定位符 URL。

❷ 万维网服务器把该元文件装入 HTTP 响应报文的主体，发回给浏览器。在响应报文中还有指明该音频/视频文件类型的首部。

❸ 客户机浏览器收到万维网服务器的响应，分析其内容类型首部行，调用相关的媒体播放器（客户机中可能装有多个媒体播放器），把提取出的元文件传送给媒体播放器。

❹ 媒体播放器使用元文件中的 URL 直接和万维网服务器建立 TCP 连接，并向万维网服务器发送 HTTP 请求报文，要求下载浏览器想要的音频/视频文件。

❺ 万维网服务器发送 HTTP 响应报文，把该音频/视频文件发送给媒体播放器。媒体播放器在存储了若干秒的音频/视频文件后（这是为了消除抖动），就以音频/视频流的形式边下载、边解压缩、边播放。

8.2.2 媒体服务器

为了更好地提供播放流式音频/视频文件的服务，现在最为流行的做法就是使用两个分开的服务器。如图 8-6 所示，现在使用一个普通的万维网服务器，和另一个媒体服务器(media server)。媒体服务器和万维网服务器可以运行在一个端系统内，也可以运行在两个不同的端系统中。媒体服务器与普通的万维网服务器的最大区别就是，媒体服务器是专门为播放流式音频/视频文件而设计的，因此能够更加有效地为用户提供播放流式多媒体文件的服务。因此媒体服务器也常被称为流式服务器(streaming server)。下面我们介绍其工作原理。



图 8-6 使用媒体服务器

在用户端的媒体播放器与媒体服务器的关系是客户与服务器的关系。与图 8-5 不同的是，现在媒体播放器不是向万维网服务器而是向媒体服务器请求音频/视频文件。媒体服务器和媒体播放器之间采用另外的协议进行交互。

采用媒体服务器后，下载音频/视频文件的前三个步骤仍然和上一节所述的一样，区别就是后面两个步骤，即：

❶~❸ 前三个步骤与图 8-5 中的相同。

❹ 媒体播放器使用元文件中的 URL 接入到媒体服务器，请求下载浏览器所请求的音频/视频文件。下载文件可以使用上一小节讲过的 HTTP/TCP，也可以借助于使用 UDP 的任何协议，例如使用实时传输协议 RTP（见 8.3.3 节）。

❺ 媒体服务器给出响应，把该音频/视频文件发送给媒体播放器。媒体播放器在迟延了若干秒后（例如，2~5 秒），以流的形式边下载、边解压缩、边播放。

上面提到，传送音频/视频文件可以使用 TCP，也可以使用 UDP。起初人们选用 UDP 来传送。不采用 TCP 的主要原因是担心当网络出现分组丢失时，TCP 的重传机制会使重传的分组不能按时到达接收端，使得媒体播放器的播放不流畅。但后来的实践经验发现，采用 UDP 会有以下几个缺点。

(1) 发送端按正常播放的速率发送流媒体数据帧，但由于网络的情况多变，在接收端的播放器很难做到始终按规定的速率播放。例如，一个视频节目需要以 1 Mbit/s 的速率播放。如果从媒体服务器到媒体播放器之间的网络容量突然降低到 1 Mbit/s 以下，那么这时就会出现播放器的暂停，影响正常的观看。

(2) 很多单位的防火墙往往阻拦外部 UDP 分组的进入，因而使用 UDP 传送多媒体文件时会被防火墙阻拦掉。

(3) 使用 UDP 传送流式多媒体文件时，如果在用户端希望能够控制媒体的播放，如进行暂停、快进等操作，那么还需要使用另外的协议 RTP（见 8.3.3 节）和 RTSP（见 8.2.3 节）。这样就增加了成本和复杂性。

于是，现在对流式存储音频/视频的播放，如 YouTube 和 Netflix^①，都采用 TCP 来传送。图 8-7 说明了使用 TCP 传送流式视频的几个主要步骤[KURO17]。

① 注：YouTube（油管）是全球最大的视频网站，能支持数百万用户同时观看流畅的视频节目，也支持网民上传自己制作的共享视频节目。Netflix（奈飞，或网飞）是世界上最大的在线影片租赁提供商，可提供超过 85000 部 DVD 电影的租赁服务，以及 4000 多部影片或者电视剧的在线观看服务。

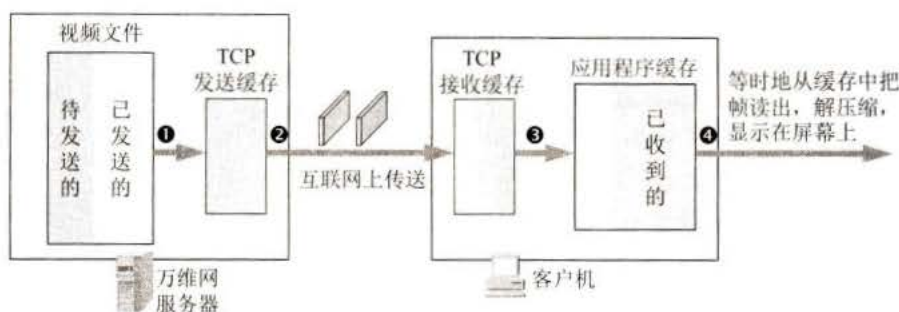


图 8-7 使用 TCP 传送流式视频的主要步骤

步骤①：用户使用 HTTP 获取存储在万维网服务器中的视频文件，然后把视频数据传送到 TCP 发送缓存中。若发送缓存已填满，就暂时停止传送。

步骤②：从 TCP 发送缓存通过互联网向客户机中的 TCP 接收缓存传送视频数据，直到接收缓存被填满。

步骤③：从 TCP 接收缓存把视频数据再传送到应用程序缓存（即媒体播放器的缓存）。这叫作预先存储。当预先存储在缓存中的视频数据存储到一定数量时，就开始播放。这个过程一般不超过 1 分钟。

步骤④：在播放时，媒体播放器等时地（即周期性地）把视频数据按帧读出，经解压缩后，把视频节目显示在用户的屏幕上。

请注意。这里只有步骤④的读出速率是严格按照源视频文件的规定速率来播放的。而前面的三个步骤中的数据传送速率则可以是任意的。如果用户暂停播放，那么图中的三个缓存将很快被填满，这时 TCP 发送缓存就暂停读取所要传送的视频文件，否则就会引起视频数据的丢失。以后，当用户继续播放时，媒体播放器每读出 n bit，TCP 发送缓存就可以从存储的视频文件再读取 n bit。如果客户机中的两个缓存经常处于填满状态，就能够较好地应付网络中偶然出现的拥塞。

如果步骤②的传送速率小于步骤④的读出速率，那么客户机中的两个缓存中的存量就会逐渐减少。当媒体播放器缓存的数据被取空后，播放就不得不暂停，直到后续的视频数据重新注入进来后才能再继续播放。实践证明，只要在步骤②的 TCP 平均传送速率达到视频节目规定的播放速率的两倍，媒体播放器一般就能流畅地播放网上的视频节目。

这里要指出，如果是观看实况转播，那么最好应当首先考虑使用 UDP 来传送。如果使用 TCP 传送，则当出现网络严重拥塞而产生播放的暂停时，就会使人难于接受。使用 UDP 传送时，即使因网络拥塞丢失了一些分组，对观看的感觉也会比突然出现暂停要好些。

顺便指出，我们在家中的宽带上网并不能保证媒体播放器一定能够流畅地回放任何视频节目。这是因为网络运营商只能保证，从用户家中到网络运营商的某个路由器之间的这段网络的数据速率。但从网络运营商到互联网上下载视频的某个媒体服务器的这段网络状况则是未知的，很可能在某些时段会出现一些网络拥塞。此外，还要考虑所选的视频节目的清晰度所要求的传输带宽。我们都知道，DVD 质量的视频和高清电视或 4K 超高清视频节目所要求的网速就相差很远。

流式媒体播放器问世后就很受欢迎。网民们不需要再随身携带刻录有视频节目的光盘，只要有能够上网的智能手机或轻巧的平板电脑，就能够随时上网观看各种视频音频节目。曾经在城市中很热闹的光盘销售商店，由于受到流式媒体的冲击，现已变得相当萧条。

8.2.3 实时流式协议 RTSP

实时流式协议 RTSP (Real-Time Streaming Protocol) 是 IETF 的 MMUSIC 工作组 (Multipart Multimedia Session Control WG, 多方多媒体会话控制工作组) 开发的协议, 现在是 RTSP 2.0 [RFC 7826, 建议标准]。RTSP 是为了给流式过程增加更多的功能而设计的协议。RTSP 本身并不传送数据, 而仅仅是使媒体播放器能够控制多媒体流的传送 (有点像文件传送协议 FTP 有一个控制信道), 因此 RTSP 又称为带外协议 (out-of-band protocol)。

RTSP 协议以客户-服务器方式工作, 它是一个应用层的多媒体播放控制协议, 用来使用户在播放从互联网下载的实时数据时能够进行控制 (像在影碟机上那样的控制), 如: 暂停/继续、快退、快进等。因此, RTSP 又称为“互联网录像机遥控协议”。

RTSP 的语法和操作与 HTTP 协议的相似 (所有的请求和响应报文都是 ASCII 文本)。但与 HTTP 不同的地方是 RTSP 是有状态的协议 (HTTP 是无状态的)。RTSP 记录客户机所处的状态 (初始化状态、播放状态或暂停状态)。RFC 7826 还规定, RTSP 控制分组既可在 TCP 上传送, 也可在 UDP 上传送。RTSP 没有定义音频/视频的压缩方案, 也没有规定音频/视频在网络中传送时应如何封装在分组中。RTSP 不规定音频/视频流在媒体播放器中应如何缓存。

在使用 RTSP 的播放器中比较著名的是苹果公司的 QuickTime 和 Real Networks 公司的 RealPlayer。

图 8-8 表示使用 RTSP 的媒体服务器的工作过程。



图 8-8 使用 RTSP 的媒体服务器的工作过程

- 1 浏览器使用 HTTP 的 GET 报文向万维网服务器请求音频/视频文件。
- 2 万维网服务器从浏览器发送携带有元文件的响应。
- 3 浏览器把收到的元文件传送给媒体播放器。
- 4 媒体播放器的 RTSP 客户发送 SETUP 报文与媒体服务器的 RTSP 服务器建立连接。
- 5 媒体服务器的 RTSP 服务器发送响应 RESPONSE 报文。
- 6 媒体播放器的 RTSP 客户发送 PLAY 报文开始下载音频/视频文件 (即开始播放)。
- 7 媒体服务器的 RTSP 服务器发送响应 RESPONSE 报文。

此后，音频/视频文件被下载，所用的协议是运行在 UDP 上的。可以是后面要介绍的 RTP，也可以是其他专用的协议。在音频/视频流播放的过程中，媒体播放器可以随时暂停（利用 PAUSE 报文）和继续播放（利用 PLAY 报文），也可以快进或快退。

⑧ 用户在不继续观看时，可以由 RTSP 客户发送 TEARDOWN 报文断开连接。

⑨ 媒体服务器的 RTSP 服务器发送响应 RESPONSE 报文。

请注意，以上编号的步骤④至⑨都使用实时流协议 RTSP。在图 8-8 中步骤⑦后面没有编号的“音频/视频流”则使用另外的传送音频/视频数据的协议，如 RTP。

8.3 交互式音频/视频

限于篇幅，在本节中我们只介绍交互式音频，即 IP 电话。IP 电话是在互联网上传送多媒体信息的一个例子。通过 IP 电话的讨论，可以有助于了解在互联网上传送多媒体信息应当解决好哪些问题。

8.3.1 IP 电话概述

1. 狭义的和广义的 IP 电话

IP 电话有多个英文同义词。常见的有 VoIP (Voice over IP), Internet Telephony 和 VON (Voice On the Net)。但 IP 电话的含义却有不同的解释。

狭义的 IP 电话就是指在 IP 网络上打电话。所谓“IP 网络”就是“使用 IP 协议的分组交换网”的简称。这里的网络可以是互联网，也可以是包含有传统的电路交换网的互联网，不过在互联网中至少要有一个 IP 网络。

广义的 IP 电话则不仅仅是电话通信，而且还可以是在 IP 网络上进行交互式多媒体实时通信（包括话音、视像等），甚至还包括即时传信 IM (Instant Messaging)。即时传信是在上网时就能从屏幕上得知有哪些朋友也正在上网。若有，则彼此可在网上即时交换信息（文字的或声音的），也包括使用一点对多点的多播技术。目前流行的即时传信应用程序有微信、Skype、QQ 和 MSN Messenger [CHEN07]，很受网民的欢迎。IP 电话可看成是一个正在演进的多媒体服务平台，是话音、视像、数据综合的基础结构。在某些条件下（例如使用宽带的局域网），IP 电话的话音质量甚至还优于普通电话。

下面讨论狭义的 IP 电话[COLL01]，而广义的 IP 电话在原理上是一样的。

其实 IP 电话并非新概念。早在 20 世纪 70 年代初期 ARPANET 刚开始运行不久，美国即着手研究如何在计算机网络上传送电话信息，即所谓的分组话音通信。但在很长一段时间里，分组话音通信发展得并不快。主要的原因是：

- (1) 缺少廉价的高质量、低速率的话音信号编解码软件和相应的芯片。
- (2) 计算机网络的传输速率和路由器处理速率均不够快，因而导致传输时延过大。
- (3) 没有保证实时通信服务质量 QoS (Quality of Service) 的网络协议。
- (4) 计算机网络的规模较小，而通信网只有在具有一定规模后才能产生经济效益。

2. IP 电话网关

然而到了 20 世纪 90 年代中期，上述的几个问题才相继得到了较好的解决。于是美国的

VocalTec 公司在 1995 年初率先推出了实用化的 IP 电话。但是这种 IP 电话必须使用 PC。1996 年 3 月, IP 电话进入了一个转折点: VocalTec 公司成功地推出了 IP 电话网关 (IP Telephony Gateway), 它是公用电话网^①与 IP 网络的接口设备。IP 电话网关的作用就是:

- (1) 在电话呼叫阶段和呼叫释放阶段进行电话信令的转换。
- (2) 在通话期间进行话音编码的转换。

有了这种 IP 电话网关, 就可实现 PC 用户到固定电话用户打 IP 电话 (仅需经过 IP 电话网关一次), 以及固定电话用户之间打 IP 电话 (需要经过 IP 电话网关两次)。

图 8-9 画出了 IP 电话几种不同的连接方式。图中最上面的情况最简单, 是两个 PC 用户之间的通话。这当然不需要经过 IP 电话网关, 但必须是双方都同时上网才能进行通话。图 8-9 中间的一种情况是 PC 到固定电话之间的通话。最后一种情况是两个固定电话之间打 IP 电话, 这当然是最方便的。读者应当特别注意在哪一部分是使用电路交换还是分组交换。

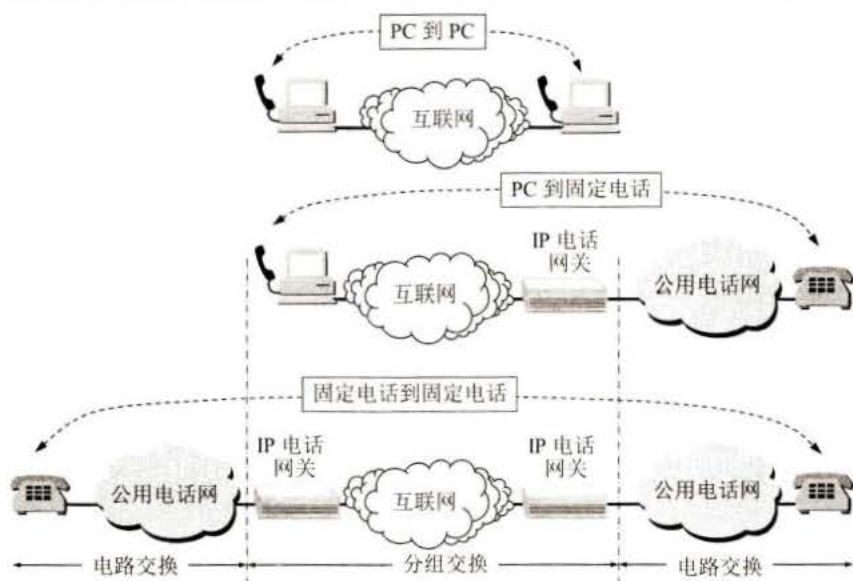


图 8-9 IP 电话的几种连接方法

3. IP 电话的通话质量

IP 电话的通话质量与电路交换电话网的通话质量有很大差别。在电路交换电话网中, 任何两端之间的通话质量都是有保证的。但 IP 电话则不然。IP 电话的通话质量主要由两个因素决定, 一个是通话双方端到端的时延和时延抖动, 另一个是话音分组的丢失率。但这两个因素都是不确定的, 而是取决于当时网络上的通信量。若网络上的通信量非常大以致发生了网络拥塞, 那么端到端时延和时延抖动以及分组丢失率都会很高, 这就导致 IP 电话的通话质量下降。因此, 一个用户使用 IP 电话的通话质量取决于当时其他许多用户的行为。请注意, 电路交换电话网的情况则完全不是这样。当电路交换电话网的通信量太大时, 往往使我们无法拨通电话 (听到的是忙音), 即电话网拒绝对正在拨号的用户提供接通服务。但是

^① 注: 公用电话网即公用电路交换电话网, 又称为传统电话网或电信网。

只要我们拨通了电话,那么电信公司就能保证让用户享受满意的通话质量。

经验证明,在电话交谈中,端到端的时延不应超过 250 ms,否则交谈者就会感到不自然。陆地公用电话网的时延一般只有 50~70 ms。但经过同步卫星的电话端到端时延就超过 250 ms,一般人都不太适应经过卫星传送的过长的时延。IP 电话的时延有时 would 超过 250 ms,因此 IP 电话必须努力减小端到端的时延。当通信线路产生回声时,则容许的端到端时延就更小些(有时甚至只容许几十毫秒的时延)。

IP 电话端到端时延是由以下几个因素造成的:

- (1) 话音信号进行模数转换要产生时延。
- (2) 已经数字化的话音比特流要积累到一定的数量才能够装配成一个话音分组,这也会产生时延。
- (3) 话音分组的发送需要时间,此时间等于话音分组长度与通信线路的数据率之比。
- (4) 话音分组在互联网中经过许多路由器的存储转发时延。
- (5) 话音分组到达接收端在缓存中暂存所引起的时延。
- (6) 将话音分组还原成模拟话音信号的数模转换也要产生一定的时延。
- (7) 话音信号在通信线路上的传播时延。
- (8) 由终端设备的硬件和操作系统产生的接入时延。由 IP 电话网关引起的接入时延约为 20~40 ms,而用户 PC 声卡引起的接入时延为 20~180 ms。有的调制解调器(如 V.34)还会再增加 20~40 ms 的时延(由于进行数字信号处理、均衡等)。

话音信号在通信线路上的传播时延一般都很小(卫星通信除外),通常可不予考虑。当采用高速光纤主干网时,上述的第三项时延也不大。

第一、第二和第六项时延取决于话音编码的方法。很明显,在保证话音质量的前提下,话音信号的数码率应尽可能低些。为了能够在世界范围提供 IP 电话服务,话音编码就必须采用统一的国际标准。ITU-T 已制定出不少话音质量不错的低速率话音编码的标准。目前适合 IP 电话使用的 ITU-T 标准主要有以下两种:

(1) G.729 话音速率为 8 kbit/s 的共轭结构代数码激励线性预测 CS-ACELP (Conjugate-Structure Algebraic-Code-Excited Linear Prediction) 声码器。

(2) G.723.1 话音速率为 5.3/6.3 kbit/s 的线性预测编码 LPC (Linear Prediction Coding) 声码器。

这两种标准的比较见表 8-1。

表 8-1 G.729 和 G.723.1 的主要性能比较

标准	比特率 (kbit/s)	帧大小 (ms)	处理时延 (ms)	帧长 (字节)	数字信号处理 MIPS
G.729	8	10	10	10	20
G.723.1	5.3/6.3	30	30	20/24	16

表中的比特率是输入为 64 kbit/s 标准 PCM 信号时在编码器输出的数据率。帧大小是压缩到每一个分组中的话音信号时间长度。处理时间是对一个帧运行编码算法所需的时间。帧长是一个已编码的帧的字节数(不包括首部)。数字信号处理 MIPS(每秒百万指令)是用数字信号处理芯片实现编码所需的最小处理机速率(以每秒百万指令为单位)。如使用 PC 的通用处理机,则所需的处理机 MIPS 还要高些。不难看出, G.723.1 标准虽然可得到更低的数据率,但其时延也更大些。

要减少上述第四和第五项时延较为困难。当网络发生拥塞而产生语音分组丢失时，还必须采用一定的策略（称为“丢失掩蔽算法”）对丢失的语音分组进行处理。例如，可使用前一个语音分组来填补丢失的语音分组的间隙。

接收端缓存空间和播放时延的大小对话音分组丢失率和端到端时延也有很大的影响。图 8-10 说明了这一问题。语音质量可分为四个级别，即“长途电话质量”（这是最好的质量）、“良好”“基本可用”和“不好”，各对应于图 8-10 中的一个区域。越接近坐标原点，语音质量就越好。我们假定某 IP 电话的通话质量处在图中 B 点的位置。若增大接收端缓存空间并增大播放时延，则语音分组丢失率将减小，但端到端的时延将增大（如图中的 C 点）。继续增大播放时延，则语音分组丢失率将继续减小，趋向于网络所引起的丢失率（如图中的 D 点），但 D 点的端到端时延很大，语音质量很不好。反之，若将接收端缓存做得很小并减小播放时延，则端到端时延将减小，趋向于网络所引起的端到端时延（如图中的 A 点），但语音分组丢失率将会大大增加，语音质量也不好。

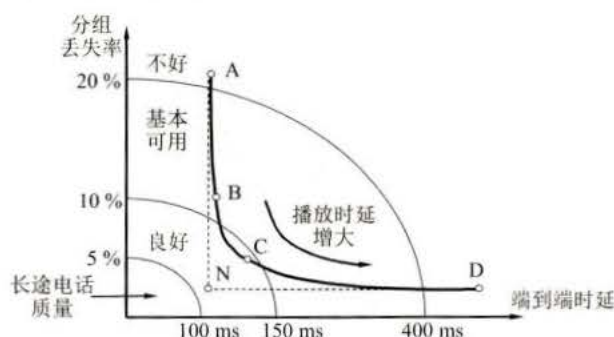


图 8-10 播放时延有一个最佳值

可见接收端的播放时延有一个最佳值。图中有一个点 N，相当于端到端时延和语音分组丢失率都是最小的，但实际上并不可能工作在这个点上。

据统计，当通话双方相距 3200 km 时，互联网上的时延约为 30~100 ms（传播和排队），而所有各环节的时延总和约为 100~262 ms（在两个 IP 电话网关之间）或 170~562 ms（在两个 PC 之间）[KAST98]。可见为了减小时延，应尽可能不要直接用 PC 打 IP 电话。

提高路由器的转发分组的速率对提高 IP 电话的质量也是很重要的。据统计，一个跨大西洋的 IP 电话一般要经过 20~30 个路由器。现在一个普通路由器每秒可转发 50~100 万个分组。若能改用吉比特路由器（又称为线速路由器），则每秒可转发 500 万至 6000 万个分组（即交换速率达 60 Gbit/s 左右）。这样还可进一步减少由网络造成的时延。

近几年来，IP 电话的质量得到了很大的提高。现在许多 IP 电话的语音质量已经优于固定电话的语音质量。一些电信运营商还建造了自己专用的 IP 电话线路，以便保证更好的通话质量。在 IP 电话领域里，最值得一提的就是 Skype IP 电话，它给全世界的广大用户带来了高品质并且廉价的通话服务。Skype 使用了 Global IP Sound 公司开发的互联网低比特率编解码器 iLBC (internet Low Bit rate Codec)[RFC 3951, 3952]，进行语音的编解码和压缩，使其语音质量优于传统的公用电话网（采用电路交换）的语音质量。Skype 支持两种帧长：20 ms（速率为 15.2 kbit/s，一个语音分组块为 304 bit）和 30 ms（速率为 13.33 kbit/s，一个语音分组块为 400 bit）。Skype 的另一个特点是对语音分组的丢失进行了特殊的处理，因而能够容忍高达 30% 的语音分组丢失率，通话的用户一般感觉不到语音的断续或迟延，杂音也很小。

Skype 采用了 P2P（见第 6 章 6.9 节的介绍）和全球索引（Global Index）技术提供快速路由选择机制（而不是单纯依靠服务器来完成这些工作），因而其管理成本大大降低，在用户呼叫时，由于用户路由信息分布式存储于互联网的节点中，因此呼叫连接完成得很快。Skype 还采用了端对端的加密方式，保证信息的安全性。Skype 在信息发送之前进行加密，在接收时进行解密，在数据传输过程中完全没有可能在中途被窃听。

由于 Skype 使用的是 P2P 的技术，用户数据主要存储在 P2P 网络中，因此必须保证存储在公共网络中的数据是可靠的和没有被篡改的。Skype 对公共目录中存储的和用户相关的数据都采用了数字签名，保证了数据无法被篡改。

自 2003 年 8 月 Skype 推出以来，在短短 15 个月内，Skype 已拥有超过 5000 万次的下载量，注册量超过 2000 万用户，并且还在以每天超过 15 万用户的速度增长。在 2011 年，在同一时间使用 Skype 的用户数已经突破了 3000 万大关。据统计，在 2014 年的国际长途电话的市场份额中，Skype 已经占据了 40%。Skype 的问世给全球信息技术和通信产业带来深远的影响，也给每一位网络使用者带来生活方式的改变。

8.3.2 IP 电话所需要的几种应用协议

在 IP 电话的通信中，我们至少需要两种应用协议。一种是信令协议，它使我们能够在互联网上找到被叫用户^①。另一种是话音分组的传送协议，它使我们用来进行电话通信的话音数据能够以时延敏感属性在互联网中传送。这样，为了在互联网中提供实时交互式的音频/视频服务，我们需要新的多媒体体系结构。

图 8-11 给出了在这样的体系结构中的三种应用层协议。第一种协议是与信令有关的，如 H.323 和 SIP（画在最左边）；第二种协议是直接传送音频/视频数据的，如 RTP（画在最右边）；第三种协议是为了提高服务质量，如 RSVP 和 RTCP（画在中间）。

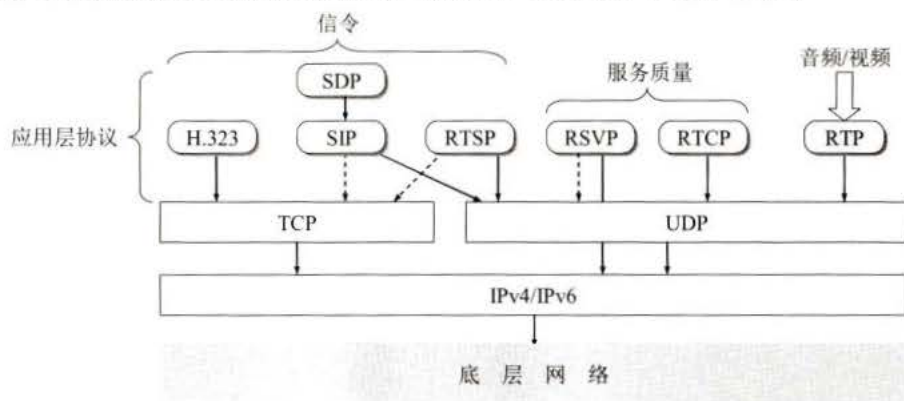


图 8-11 提供实时交互式音频/视频服务所需的应用层协议

下面先介绍实时传输协议 RTP 及其配套的协议——实时传输控制协议 RTCP，然后再介

^① 注：在公用电话网中，电话交换机根据用户所拨打的号码就能够通过合适的路由找到被叫用户，并在主叫和被叫之间建立起一条电路连接。这些都依靠电话信令(signaling)完成。我们听到的振铃声、忙音或一些录音提示，以及打完电话挂机释放连接，也都是由电话信令来处理的。现在电话网使用的信令就是 7 号信令 SS7。利用 IP 网络打电话同样也需要 IP 网络能够识别的某种信令，但由于 IP 电话往往要经过已有的公用电话网，因此 IP 电话的信令必须在所有的功能上与原有的 7 号信令相兼容，这样才能使 IP 网络和公用电话网上的两种信令能够互相转换，因而能够做到互操作。

绍 IP 电话的信令协议 H.323 和会话发起协议 SIP。

8.3.3 实时运输协议 RTP

实时运输协议 RTP (Real-time Transport Protocol) 是 IETF 的 AVT 工作组(Audio/Video Transport WG)开发的协议, 现已成为互联网标准[RFC 3550, STD64] [RFC 3551, STD65]。

RTP 为实时应用提供端到端的运输, 但不提供任何服务质量的保证。需要发送的多媒体数据块(音频/视频)经过压缩编码处理后, 先送给 RTP 封装成为 RTP 分组(也可称为 RTP 报文^①)。RTP 分组装入运输层的 UDP 用户数据报后, 再向下递交给 IP 层。RTP 现已成为互联网正式标准, 并且已被广泛使用。RTP 同时也是 ITU-T 的标准(H.225.0)。实际上, RTP 是一个协议框架, 因为它只包含了实时应用的一些共同功能。RTP 自己并不对多媒体数据块做任何处理, 而只是向应用层提供一些附加的信息, 让应用层知道应当如何处理。

图 8-11 把 RTP 协议画在应用层。这是因为从应用开发者的角度看, RTP 应当是应用层的一部分。在应用程序的发送端, 开发者必须编写用 RTP 封装分组的程序代码, 然后把 RTP 分组交给 UDP 套接字接口。在接收端, RTP 分组通过 UDP 套接字接口进入应用层后, 还要利用开发者编写的程序代码从 RTP 分组中把应用数据块提取出来。

然而 RTP 的名称又隐含地表示它是一个运输层协议。这样划分也是可以的, 因为 RTP 封装了多媒体应用的数据块, 并且由于 RTP 向多媒体应用程序提供了服务(如时间戳和序号), 因此也可以把 RTP 看成是在 UDP 之上的一个运输层子层的协议。

RTP 还有两点值得注意。首先, RTP 分组只包含 RTP 数据, 而控制是由另一个配套使用的 RTCP 协议提供的(这在下一节介绍)。其次, RTP 在端口号 1025 到 65535 之间选择一个未使用的偶数 UDP 端口号, 而在同一次会话中的 RTCP 则使用下一个奇数 UDP 端口号。但端口号 5004 和 5005 则分别用作 RTP 和 RTCP 的默认端口号。

图 8-12 给出了 RTP 分组的首部格式, 下面进行简单的介绍。

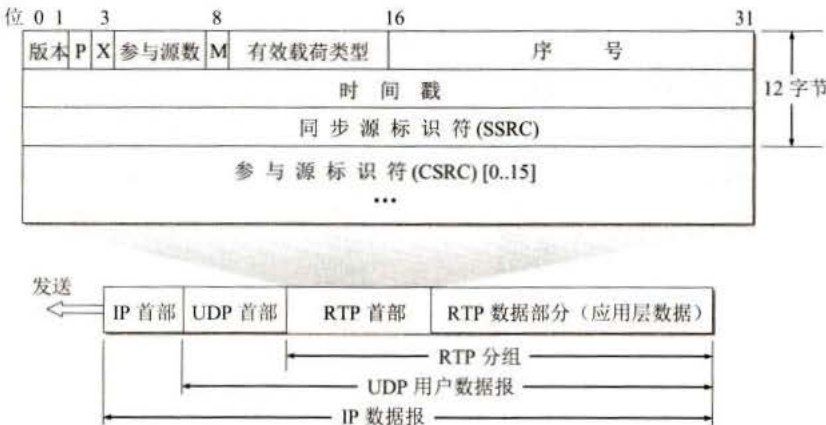


图 8-12 RTP 分组的首部格式

① 注: 按惯例, 在运输层或应用层的协议数据单元应当叫作报文。但相关 RFC 文档中都是使用 RTP packet 这一名词的。为了和 RFC 文档一致, 这里也使用“RTP 分组”。下一节的 RTCP 也按同样方法处理。

在 RTP 分组的首部中, 前 12 个字节是必需的, 而 12 字节以后的部分则是可选的。下面按照各字段重要性的顺序来进行介绍。

(1) **有效载荷类型(payload type)** 占 7 位。这个字段指出后面的 RTP 数据属于何种格式的应用。收到 RTP 分组的应用层就根据此字段指出的类型进行处理。例如, 对于音频有效载荷 (每一种格式后面括弧中的数字就表示其有效载荷类型的编码): μ 律 PCM (0), GSM (3), LPC (7), A 律 PCM (8), G.722 (9), G.728 (15)等。对于视频有效载荷: 活动 JPEG (26), H.261 (31), MPEG1 (32), MPEG2 (33)等。

(2) **序号** 占 16 位。对每一个发送出的 RTP 分组, 其序号加 1。在一次 RTP 会话开始时的初始序号是随机选择的。序号使接收端能够发现丢失的分组, 同时也能将失序的 RTP 分组重新按序排列好。例如, 在收到序号为 60 的 RTP 分组后又收到了序号为 65 的 RTP 分组。那么就可推断出, 中间还缺少序号为 61 至 64 的 4 个 RTP 分组。

(3) **时间戳** 占 32 位。时间戳反映了 RTP 分组中数据的第一个字节的采样时刻。在一次会话开始时时间戳的初始值也是随机选择的。即使在没有信号发送时, 时间戳的数值也要随时间而不断地增加。接收端使用时间戳可准确知道应当在什么时间还原哪一个数据块, 从而消除时延的抖动。时间戳还可以用来使视频应用中声音和图像同步。在 RTP 协议中并没有规定时间戳的粒度, 这取决于有效载荷的类型。因此 RTP 的时间戳又称为**媒体时间戳**, 以强调这种时间戳的粒度取决于信号的类型。例如, 对于 8 kHz 采样的话音信号, 若每隔 20 ms 构成一个数据块, 则一个数据块中包含有 160 个样本 ($0.02 \times 8000 = 160$)。因此发送端每发送一个 RTP 分组, 其时间戳的值就增加 160。

(4) **同步源标识符** 占 32 位。**同步源标识符 SSRC (Synchronous SouRCe identifier)**是一个数, 用来标志 RTP 流(stream)的来源。SSRC 与 IP 地址无关, 在新的 RTP 流开始时随机地产生。由于 RTP 使用 UDP 传送, 因此可以有多个 RTP 流 (例如, 使用几个摄像机从不同角度拍摄同一个节目所产生的多个 RTP 流) 复用到一个 UDP 用户数据报中。SSRC 可使接收端的 UDP 能够将收到的 RTP 流送到各自的终点。两个 RTP 流恰好都选择同一个 SSRC 的概率是极小的。若发生这种情况, 这两个源就都重新选择另一个 SSRC。

(5) **参与源标识符** 这是选项, 最多可有 15 个。**参与源标识符 CSRC (Contributing SouRCe identifier)**也是一个 32 位数, 用来标志来源于不同地点的 RTP 流。在多播环境中, 可以用中间的一个站 (叫作**混合站 mixer**) 把发往同一个地点的多个 RTP 流混合成一个流 (可节省通信资源), 在目的站再根据 CSRC 的数值把不同的 RTP 流分开。

(6) **参与源数** 占 4 位。这个字段给出后面的参与源标识符的数目。

(7) **版本** 占 2 位。当前使用的是版本 2。

(8) **填充 P** 占 1 位。在某些特殊情况下需要对应用数据块加密, 这往往要求每一个数据块有确定的长度。如不满足这种长度要求, 就需要进行填充。这时就把 P 位置 1, 表示这个 RTP 分组的数据有若干填充字节。在数据部分的最后一个字节用来表示所填充的字节数。

(9) **扩展 X** 占 1 位。X 置 1 表示在此 RTP 首部后面还有扩展首部。扩展首部很少使用, 这里不再讨论。

(10) **标记 M** 占 1 位。M 置 1 表示这个 RTP 分组具有特殊意义。例如, 在传送视频流时用来表示每一帧的开始。

8.3.4 实时运输控制协议 RTCP

实时运输控制协议 RTCP (RTP Control Protocol)是与 RTP 配合使用的协议[RFC 3550, 3551], 实际上, RTCP 协议也是 RTP 协议不可分割的部分。

RTCP 协议的主要功能是: 服务质量的监视与反馈、媒体间的同步(如某一个 RTP 发送的声音和图像的配合), 以及多播组中成员的标志。RTCP 分组(也可称为 RTCP 报文)也使用 UDP 来传送, 但 RTCP 并不对音频/视频分组进行封装。由于 RTCP 分组很短, 因此可把多个 RTCP 分组封装在一个 UDP 用户数据报中。RTCP 分组周期性地在网上传送, 它带有发送端和接收端对服务质量的统计信息报告(例如, 已发送的分组数和字节数、分组丢失率、分组到达时间间隔的抖动等)。

表 8-2 是 RTCP 使用的五种分组类型, 它们都使用同样的格式。

表 8-2 RTCP 的五种分组类型

类型	缩写表示	意义
200	SR	发送端报告
201	RR	接收端报告
202	SDES	源点描述
203	BYE	结束
204	APP	特定应用

结束分组 BYE 表示关闭一个数据流。

特定应用分组 APP 使应用程序能够定义新的分组类型。

接收端报告分组 RR 用来使接收端周期性地向所有的点用多播方式进行报告。接收端每收到一个 RTP 流(一次会话包含有许多的 RTP 流)就产生一个接收端报告分组 RR。RR 分组的内容有: 所收到的 RTP 流的 SSRC; 该 RTP 流的分组丢失率(若分组丢失率太高, 发送端就应当适当降低发送分组的速率); 在该 RTP 流中的最后一个 RTP 分组的序号; 分组到达时间间隔的抖动等。

发送 RR 分组有两个目的: 第一, 可以使所有的接收端和发送端了解当前网络的状态; 第二, 可以使所有发送 RTCP 分组的站点自适应地调整自己发送 RTCP 分组的速率, 使得起控制作用的 RTCP 分组不要过多地影响传送应用数据的 RTP 分组在网络中的传输。通常是使 RTCP 分组的通信量不超过网络中数据分组的通信量的 5%, 而接收端报告分组的通信量又应小于所有 RTCP 分组的通信量的 75%。

发送端报告分组 SR 用来使发送端周期性地向所有接收端用多播方式进行报告。发送端每发送一个 RTP 流, 就要发送一个发送端报告分组 SR。SR 分组的主要内容有: 该 RTP 流的同步源标识符 SSRC; 该 RTP 流中最新产生的 RTP 分组的时间戳和绝对时钟时间(或墙上时钟时间 wall clock time); 该 RTP 流包含的分组数; 该 RTP 流包含的字节数。

绝对时钟时间是必要的。因为 RTP 要求每一种媒体使用一个流。例如, 要传送视频图像和相应的声音就需要传送两个流。有了绝对时钟时间就可进行图像和声音的同步。

源点描述分组 SDES 给出会话中参加者的描述, 它包含参加者的规范名 CNAME (Canonical NAME)。规范名是参加者的电子邮件地址的字符串。

8.3.5 H.323

现在 IP 电话有两套信令标准：一套是 ITU-T 定义的 H.323 协议，另一套是 IETF 提出的会话发起协议 SIP (Session Initiation Protocol)。我们先介绍 H.323 协议。

H.323 是 ITU-T 于 1996 年制定的为在局域网上传送话音信息的建议书。1998 年 H.323 的第二个版本改用的名称是“基于分组的多媒体通信系统”。在 2009 年已更新到 H.323v7。基于分组的网络包括互联网、局域网、企业网、城域网和广域网。H.323 是互联网的端系统之间进行实时声音和视频会议的标准。请注意，H.323 不是一个单独的协议而是一组协议。H.323 包括系统和构件的描述、呼叫模型的描述、呼叫信令过程、控制报文、复用、话音编解码器、视像编解码器，以及数据协议等。图 8-13 示意了连接在分组交换网上的 H.323 终端使用 H.323 协议进行多媒体通信。



图 8-13 H.323 终端使用 H.323 协议进行多媒体通信

H.323 标准指明了四种构件，使用这些构件连网就可以进行点对点或一点对多点的多媒体通信。

(1) **H.323 终端** 这可以是一个 PC，也可以是运行 H.323 程序的单个设备。

(2) **网关** 网关连接到两种不同的网络，使得 H.323 网络可以和非 H.323 网络（如公用电话网）进行通信。仅在一个 H.323 网络上通信的两个终端当然就不需要使用网关。

(3) **网闸(gatekeeper)** 网闸相当于整个 H.323 网络的大脑。所有的呼叫都要通过网闸，因为网闸提供地址转换、授权、带宽管理和计费功能。网闸还可以帮助 H.323 终端找到距离公用电话网上的被叫用户最近的一个网关。

(4) **多点控制单元 MCU (Multipoint Control Unit)** MCU 支持三个或更多的 H.323 终端的音频或视频会议。MCU 管理会议资源、确定使用的音频或视频编解码器。

网关、网闸和 MCU 在逻辑上是分开的构件，但它们可实现在一个物理设备中。在 H.323 标准中，将 H.323 终端、网关和 MCU 都称为 H.323 端点(end point)。

图 8-14 表示了利用 H.323 网关使互联网能够和公用电话网进行连接。



图 8-14 H.323 网关用来和非 H.323 网络进行连接

图 8-15 给出了 H.323 的体系结构。可以看出，H.323 是一个协议族，它可以使用不同的运输协议。H.323 包括以下一些组成部分：

音频/视频应用		信令和控制在控制			数据应用	
音频编解码	视频编解码	RTCP	H.225.0 登记信令	H.225.0 呼叫信令	H.245 控制信令	T.120 数据
RTP						
UDP				TCP		
IP						

图 8-15 H.323 的协议体系结构

(1) 音频编解码器 H.323 要求至少要支持 G.711 (64 kbit/s 的 PCM)。建议支持如 G.722 (16 kbit/s 的 ADPCM), G.723.1 (5.3/6.3 的 LPC), G.728 (16 kbit/s 的低时延 CELP) 和 G.729 (8 kbit/s 的 CS-ACELP) 等。

(2) 视频编解码器 H.323 要求必须支持 H.261 标准 (176 × 144 像素)。

(3) H.225.0 登记信令, 即登记/接纳/状态 RAS (Registration/Admission/Status)。H.323 终端和网闸使用 RAS 来完成登记、接纳控制和带宽转换等功能。

(4) H.225.0 呼叫信令 用来在两个 H.323 端点之间建立连接。

(5) H.245 控制信令 用来交换端到端的控制报文, 以便管理 H.323 端点的运行。

(6) T.120 数据传送协议 这是与呼叫相关联的数据交换协议。用户在参加音频/视频会议时, 可以和其他与会用户共享屏幕上的白板。由于使用 TCP 协议, 因此能够保证数据传送的正确 (在传送音频/视频文件时使用的是 UDP, 因此不能保证服务质量)。

(7) 实时传输协议 RTP 和实时传输控制协议 RTCP 这两个协议前面已讨论。

H.323 的出发点是以已有的电路交换电话网为基础, 增加了 IP 电话的功能 (即远距离传输采用 IP 网络)。H.323 的信令也沿用原有电话网的信令模式, 因此与原有电话网的连接比较容易。

8.3.6 会话发起协议 SIP

虽然 H.323 系列现在已被大部分生产 IP 电话的厂商采用, 但由于 H.323 过于复杂 (整个文档多达 736 页), 不便于发展基于 IP 的新业务, 因此 IETF 的 MMUSIC 工作组制定了另一套较为简单且实用的标准, 即会话发起协议 SIP (Session Initiation Protocol) [RFC 3261—3264], 目前已成为互联网的提议标准。SIP 使用了 KISS 原则: 即“保持简单、傻瓜” (Keep It Simple and Stupid)。

SIP 协议的出发点是以互联网为基础, 而把 IP 电话视为互联网上的新应用。因此 SIP 协议只涉及 IP 电话所需的信令和有关服务质量的问题, 而没有提供像 H.323 那样多的功能。SIP 没有强制使用特定的编解码器, 也不强制使用 RTP 协议。然而, 实际上大家还是选用 RTP 和 RTCP 作为配合使用的协议。

SIP 使用文本方式的客户-服务器协议。SIP 系统只有两种构件, 即用户代理 (user agent) 和网络服务器 (network server)。用户代理包括两个程序, 即用户代理客户 UAC (User Agent Client) 和用户代理服务器 UAS (User Agent Server), 前者用来发起呼叫, 后者用来接受呼叫。网络服务器分为代理服务器 (proxy server) 和重定向服务器 (redirect server)。代理服务器接受来自主叫用户的呼叫请求 (实际上是来自用户代理客户的呼叫请求), 并将其转发给被叫用户或下一跳代理服务器, 然后下一跳代理服务器再把呼叫请求转发给被叫用户 (实际上是转发给用户代理服务器)。重定向服务器不接受呼叫, 它通过响应告诉客户下一跳代理服务器

的地址，由客户按此地址向下一跳代理服务器重新发送呼叫请求。

SIP 的地址十分灵活。它可以是电话号码，也可以是电子邮件地址、IP 地址或其他类型的地址。但一定要使用 SIP 的地址格式，例如：

- 电话号码 sip:zhangsan@8625-87654321
- IPv4 地址 sip:zhangsan@201.12.34.56
- 电子邮件地址 sip:zhangsan@163.com

和 HTTP 相似，SIP 是基于报文的协议。SIP 使用了 HTTP 的许多首部、编码规则、差错码以及一些鉴别机制。它比 H.323 具有更好的可扩展性。

SIP 的会话共有三个阶段：建立会话、通信和终止会话。图 8-16 给出了一个简单的 SIP 会话的例子。图中的建立会话阶段和终止会话阶段，都是使用 SIP 协议，而中间的通信阶段，则使用如 RTP 这样的传送实时话音分组的协议。

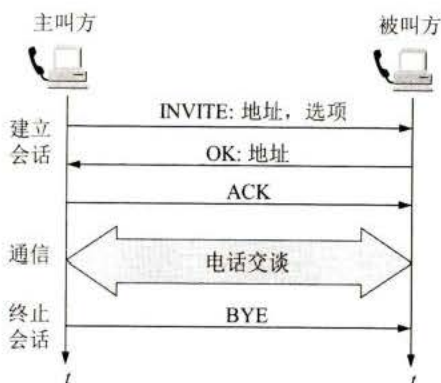


图 8-16 一个简单的 SIP 会话的例子

在图 8-16 中，主叫方先向被叫方发出 INVITE 报文，这个报文中含有双方的地址信息以及其他一些信息（如通话时话音编码方式等）。被叫方如接受呼叫，则发回 OK 响应，而主叫方再发送 ACK 报文作为确认（这和建立 TCP 连接的三报文握手相似）。然后双方就可以通话了。当通话完毕时，双方中的任何一方都可以发送 BYE 报文以终止这次的会话。

SIP 有一种跟踪用户的机制，可以找出被叫方使用的 PC 的 IP 地址（例如，被叫方使用 DHCP，因而没有固定的 IP 地址）。为了实现跟踪，SIP 使用登记的概念。SIP 定义一些服务器作为 SIP 登记器(registrar)。每一个 SIP 用户都有一个相关联的 SIP 登记器。用户在任何时候发起 SIP 应用时，都应当给 SIP 登记器发送一个 SIP REGISTER 报文，向登记器报告现在使用的 IP 地址。SIP 登记器和 SIP 代理服务器通常运行在同一台主机上。

图 8-17 说明了 SIP 登记器的用途。主叫方把 INVITE 报文发送给 SIP 代理服务器。这个 INVITE 报文中只有被叫方的电子邮件地址而没有其 IP 地址。SIP 代理服务器就向 SIP 登记器发送域名系统 DNS 查询（这个查找报文不是 SIP 的报文），然后从回答报文得到了被叫方的 IP 地址。代理服务器把得到的被叫方的 IP 地址插入到主叫方发送的 INVITE 报文中，转发给被叫方。被叫方发送 OK 响应，然后主叫方发送 ACK 报文，完成了会话的建立。